

BÁO CÁO THỰC HÀNH

Môn học: Bảo mật Web và Ứng dụng

Lab 4: Pentesting Android Applications

GVHD: Ngô Khánh Khoa

Nhóm: 11

1. THÔNG TIN CHUNG:

Lớp: NT213.P11.ANTT.2

STT	Họ và tên	MSSV	Email
1	Nguyễn Đăng Quỳnh Như	22521050	22521050@gm.uit.edu.vn
2	Phạm Minh Tân	22521310	22521310@gm.uit.edu.vn
3	Lê Minh Quân	22521181	22521181@gm.uit.edu.vn
4	Đặng Đức Tài	22521270	22521270@gm.uit.edu.vn

2. NỘI DUNG THỰC HIỆN:

STT	Nội dung	Tình trạng	Trang
1	Bài tập cơ bản (7 bài)	100%	2
2	EVABS (12 levels)	100%	17
3	picoCTF (5 levels)	100%	36
Điểm tự đánh giá			10/10

Link video youtube: [Click here](#)

Phần bên dưới của báo cáo này là tài liệu báo cáo chi tiết của nhóm thực hiện

BÁO CÁO CHI TIẾT

PHẦN I. BÀI TẬP CƠ BẢN

Yêu cầu 1 Phân tích và chỉ ra điểm bất thường của đoạn code trên?

Đây là đoạn code trong phần mềm insecurebank khi sử dụng bytecode viewer để xem:

```
public void postData(final String s) throws ClientProtocolException, IOException, JSONException, InvalidKeyException, NoSuchAlgorithmException {
    final DefaultHttpClient defaultHttpClient = new DefaultHttpClient();
    final HttpPost httpPost = new HttpPost(this.this$0.protocol + this.this$0.serverip + ":" + this.this$0.serverport + "/login");
    final HttpPost httpPost2 = new HttpPost(this.this$0.protocol + this.this$0.serverip + ":" + this.this$0.serverport + "/devlog");
    final ArrayList list = new ArrayList(2);
    list.add(new BasicNameValuePair("username", this.this$0.username));
    list.add(new BasicNameValuePair("password", this.this$0.password));
    HttpResponse httpResponse;
    if (this.this$0.username.equals("devadmin")) {
        httpPost2.setEntity((HttpEntity)new UrlEncodedFormEntity((List)list));
        httpResponse = ((HttpClient)defaultHttpClient).execute((HttpRequest)httpPost2);
    }
    else {
        httpPost.setEntity((HttpEntity)new UrlEncodedFormEntity((List)list));
        httpResponse = ((HttpClient)defaultHttpClient).execute((HttpRequest)httpPost);
    }
    this.this$0.result = this.convertStreamToString(httpResponse.getEntity().getContent());
    this.this$0.result = this.this$0.result.replace("\n", "");
    if (this.this$0.result != null) {
        if (this.this$0.result.indexOf("Correct Credentials") != -1) {
            Log.d("Successful Login:", "account=" + this.this$0.username + ":" + this.this$0.password);
            this.saveCreds(this.this$0.username, this.this$0.password);
            this.trackUserLogins();
            final Intent intent = new Intent(this.this$0.getApplicationContext(), (Class)PostLogin.class);
            intent.putExtra("uname", this.this$0.username);
            this.this$0.startActivity(intent);
        }
        else {
            this.this$0.startActivity(new Intent(this.this$0.getApplicationContext(), (Class)WrongLogin.class));
        }
    }
}
```

Các lỗi:

- Hardcoded Credentials:

- + Lỗi: Chuỗi `this.this$0.username.equals("devadmin")` chứa một giá trị "devadmin" được mã hóa cứng (hardcoded).
- + Nguy cơ: Việc mã hóa cứng tài khoản quản trị viên làm lộ thông tin quan trọng, dễ dàng bị kẻ tấn công tìm thấy nếu mã nguồn bị rò rỉ.
- + Giải pháp: Không nên lưu thông tin nhạy cảm trực tiếp trong mã nguồn. Thay vào đó, sử dụng các biến môi trường hoặc hệ thống quản lý bí mật (secret management systems).

- Plaintext Password Transmission:

- + Lỗi: Mật khẩu người dùng (`this.this$0.password`) được gửi dưới dạng văn bản thuần (plaintext) trong HTTP POST.

- + Nguy cơ: Thông tin đăng nhập có thể bị đánh cắp trong quá trình truyền qua mạng nếu không sử dụng HTTPS.
- + Giải pháp: Chỉ sử dụng giao thức HTTPS để đảm bảo mã hóa dữ liệu trong quá trình truyền.
- Static and Predictable URLs:
 - + Lỗi: URL máy chủ (e.g., `this.this$0.serverip` và `this.this$0.serverport`) được xây dựng tĩnh mà không có biện pháp xác thực hoặc mã hóa bổ sung.
 - + Nguy cơ: Nếu máy chủ bị tấn công hoặc URL bị lộ, kẻ xấu có thể khai thác để gửi yêu cầu độc hại.
 - + Giải pháp: Xác thực yêu cầu từ phía máy chủ. Thực hiện xác thực hai chiều giữa client và server (e.g., bằng TLS certificates).
- No Input Validation:
 - + Lỗi: Không kiểm tra dữ liệu đầu vào từ người dùng trước khi gửi (username/password).
 - + Nguy cơ: Dễ dẫn đến các lỗi như SQL Injection hoặc các tấn công khác nếu server-side không kiểm soát tốt.
 - + Giải pháp: Kiểm tra và xác thực dữ liệu đầu vào trước khi sử dụng, đảm bảo chúng hợp lệ (e.g., chiều dài, ký tự cho phép).
- Improper Error Handling:
 - + Lỗi: Đoạn mã không cung cấp bất kỳ biện pháp bảo vệ hoặc xử lý lỗi an toàn.
 - + Nguy cơ: Kẻ tấn công có thể đoán biết hệ thống qua các thông tin lỗi trả về.
 - + Giải pháp: Tránh cung cấp thông tin chi tiết về lỗi. Thay vào đó, sử dụng thông báo lỗi chung chung.
- Sensitive Information Storage:
 - + Lỗi: Hàm `this.saveCreds()` dường như lưu trữ thông tin nhạy cảm (username/password) mà không đề cập đến cách thức mã hóa.
 - + Nguy cơ: Nếu thông tin được lưu dưới dạng plaintext trên thiết bị, kẻ tấn công có thể dễ dàng truy cập.
 - + Giải pháp: Mã hóa dữ liệu trước khi lưu trữ. Sử dụng KeyStore hoặc cơ chế lưu trữ an toàn.
- Logging Sensitive Information:
 - + Lỗi: Đoạn mã `Log.d()` in trực tiếp thông tin đăng nhập (`this.this$0.username + ":" + this.this$0.password`) vào log.
 - + Nguy cơ: Thông tin nhạy cảm có thể bị lộ qua log files.

+ Giải pháp: Không ghi lại thông tin nhạy cảm trong log. Nếu cần, sử dụng cơ chế mã hóa.

- Potential Brute Force Vulnerability:

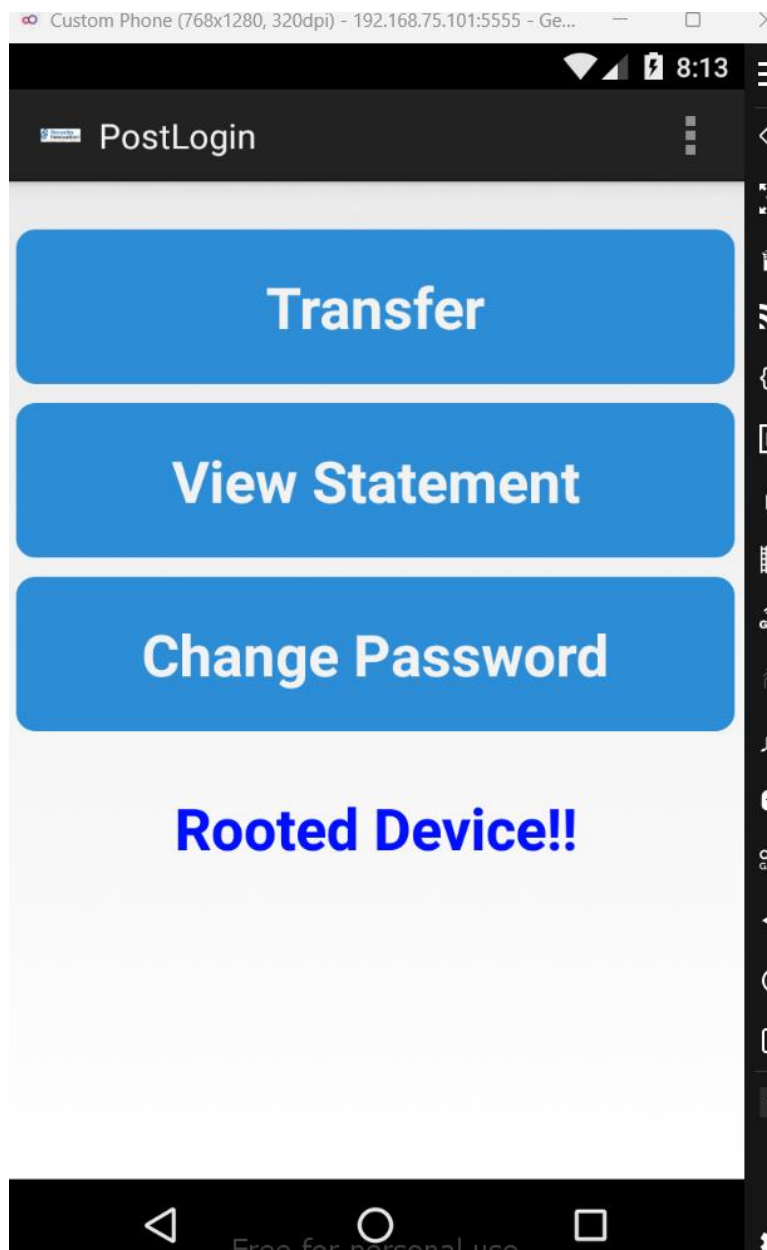
+ Lỗi: Không có cơ chế giới hạn số lần đăng nhập sai.

+ Nguy cơ: Hệ thống có thể dễ dàng bị brute force attack.

+ Giải pháp: Thêm biện pháp hạn chế số lần đăng nhập sai (e.g., khóa tài khoản sau N lần thất bại). Thêm CAPTCHA để ngăn chặn tự động hóa.

Yêu cầu 2

Chỉ ra rằng dữ liệu lưu trữ có an toàn hay không?



Sau khi đã đăng nhập thành công.

```
jenymotion:/data/data/com.android.insecurebankv2/databases # ls
mydb mydb-journal
jenymotion:/data/data/com.android.insecurebankv2/databases # sqlite3 mydb
SQLite version 3.18.2 2017-07-21 07:56:09
Enter ".help" for usage hints.
sqlite> .tables
android_metadata names
```

Vào database bằng command line của máy ảo.

```
sqlite> .database
main: /data/data/com.android.insecurebankv2/databases/mydb
sqlite> .tables
android_metadata names
sqlite> select * from names
...> ;
sqlite> select * from names
...> ;
1|dinesh
```

Truy vấn vào bảng table và gọi thông tin.

Việc lưu trữ dữ liệu ở đây là không an toàn. Vì dữ liệu được lưu ở dạng plaintext chứ không được mã hóa rồi mới lưu.

Yêu cầu 3 Kiểm tra xem thông tin nhạy cảm có lưu lại trên thiết bị hay không? Một số từ khoá: deviceId, userId, imei, deviceSerialNumber, devicePrint, phone, XDSN, mdn, IMSI, uuid...

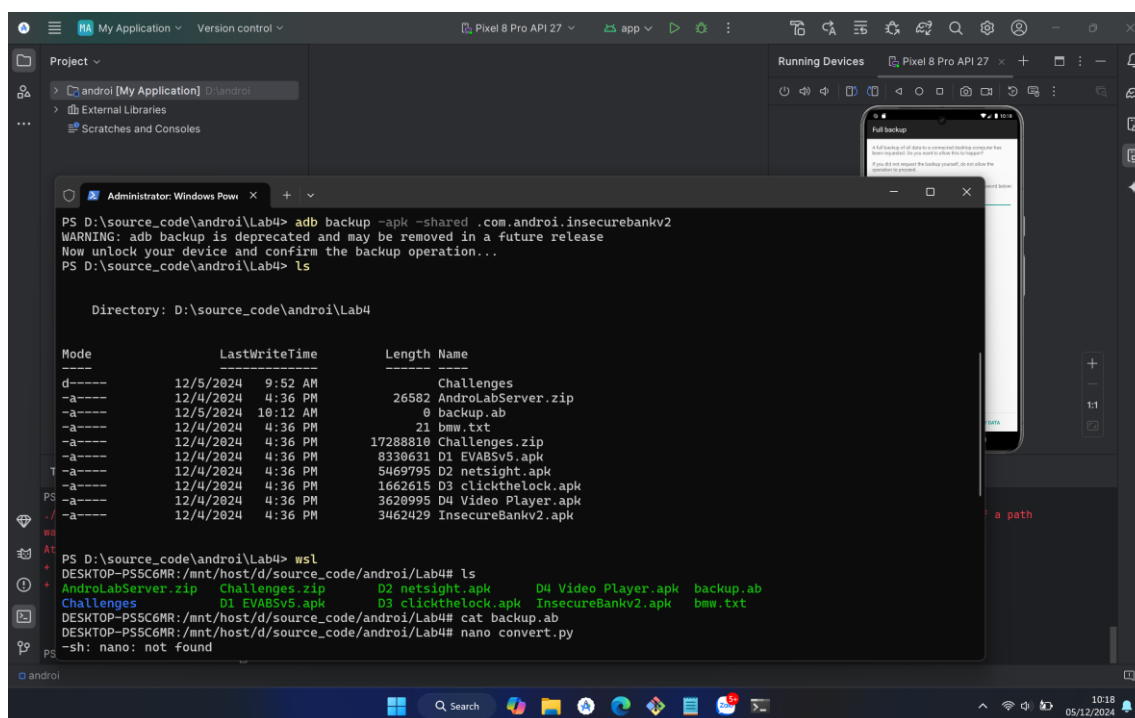
- Đầu tiên, ta truy cập vào đường dẫn data/data/com.android.insecurebankv2 và tiến hành dùng lệnh grep để tìm thông tin nhạy cảm

```
C:\Windows\System32\cmd.e x + v
sqlite>
genymotion:/data/data/com.android.insecurebankv2/databases # cd ..
genymotion:/data/data/com.android.insecurebankv2 # clear
genymotion:/data/data/com.android.insecurebankv2 # grep -r <deviced> $(find)
/system/bin/sh: can't open deviced: No such file or directory
1|genymotion:/data/data/com.android.insecurebankv2 # grep -r <userId> $(find)
/system/bin/sh: can't open userId: No such file or directory
1|genymotion:/data/data/com.android.insecurebankv2 # grep -r <deviceId> $(find)
/system/bin/sh: can't open deviceId: No such file or directory
1|genymotion:/data/data/com.android.insecurebankv2 # grep -r <imei> $(find)
/system/bin/sh: can't open imei: No such file or directory
1|genymotion:/data/data/com.android.insecurebankv2 # grep -r <deviceSerialNumber> $(find)
/system/bin/sh: can't open deviceSerialNumber: No such file or directory
1|genymotion:/data/data/com.android.insecurebankv2 # grep -r <devicePrint> $(find)
/system/bin/sh: can't open devicePrint: No such file or directory
1|genymotion:/data/data/com.android.insecurebankv2 # grep -r <phone> $(find)
/system/bin/sh: can't open phone: No such file or directory
1|genymotion:/data/data/com.android.insecurebankv2 # grep -r <XDSN> $(find)
/system/bin/sh: can't open XDSN: No such file or directory
1|genymotion:/data/data/com.android.insecurebankv2 # grep -r <mdn> $(find)
/system/bin/sh: can't open mdn: No such file or directory
1|genymotion:/data/data/com.android.insecurebankv2 # grep -r <IMSI> $(find)
/system/bin/sh: can't open IMSI: No such file or directory
1|genymotion:/data/data/com.android.insecurebankv2 # grep -r <uuid> $(find)
/system/bin/sh: can't open uuid: No such file or directory
1|genymotion:/data/data/com.android.insecurebankv2 #
```

- Sau khi kiểm tra thì không thấy thông tin nào xuất hiện cả. Có thể trong phần này không có gì để tìm kiếm thông tin nhạy cảm nào cả.

Yêu cầu 4 Theo bạn thư mục sao lưu chứa thông tin nào cần mã hoá, chỉ ra.

- Đầu tiên, chạy lệnh `adb backup -apk -shared com.android.insecurebankv2` để tiến hành backup dữ liệu



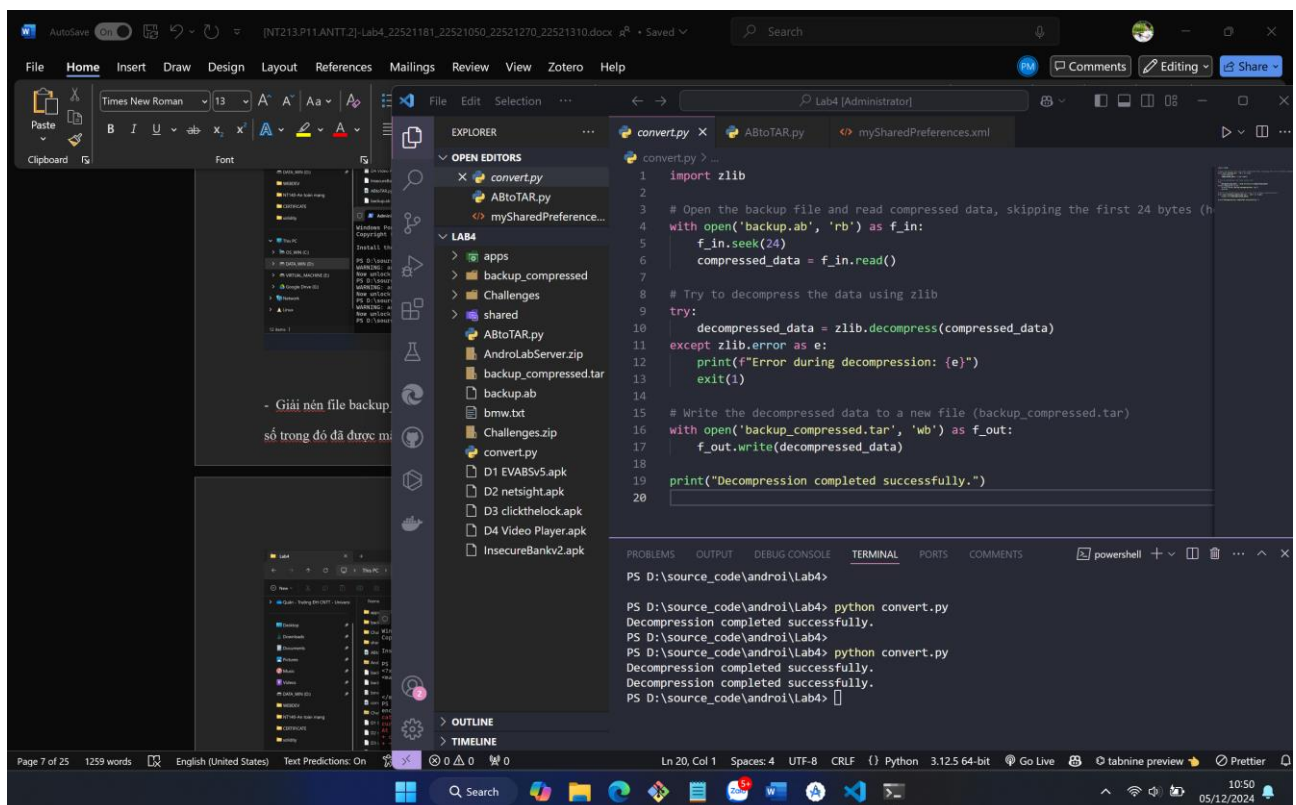
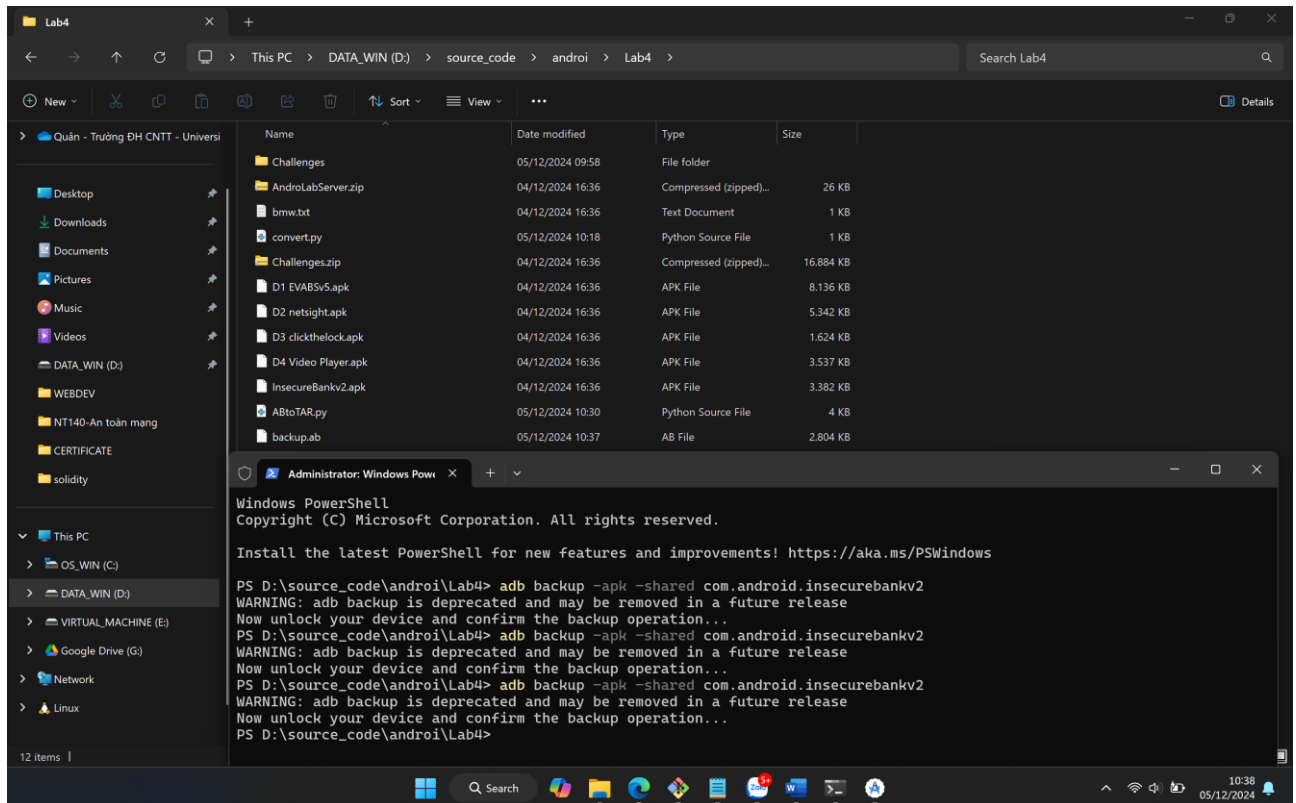
```
Administrator: Windows Powe x + v
PS D:\source_code\androi\Lab4> adb backup -apk -shared com.android.insecurebankv2
WARNING: adb backup is deprecated and may be removed in a future release
Now unlock your device and confirm the backup operation...
PS D:\source_code\androi\Lab4> ls

Directory: D:\source_code\androi\Lab4

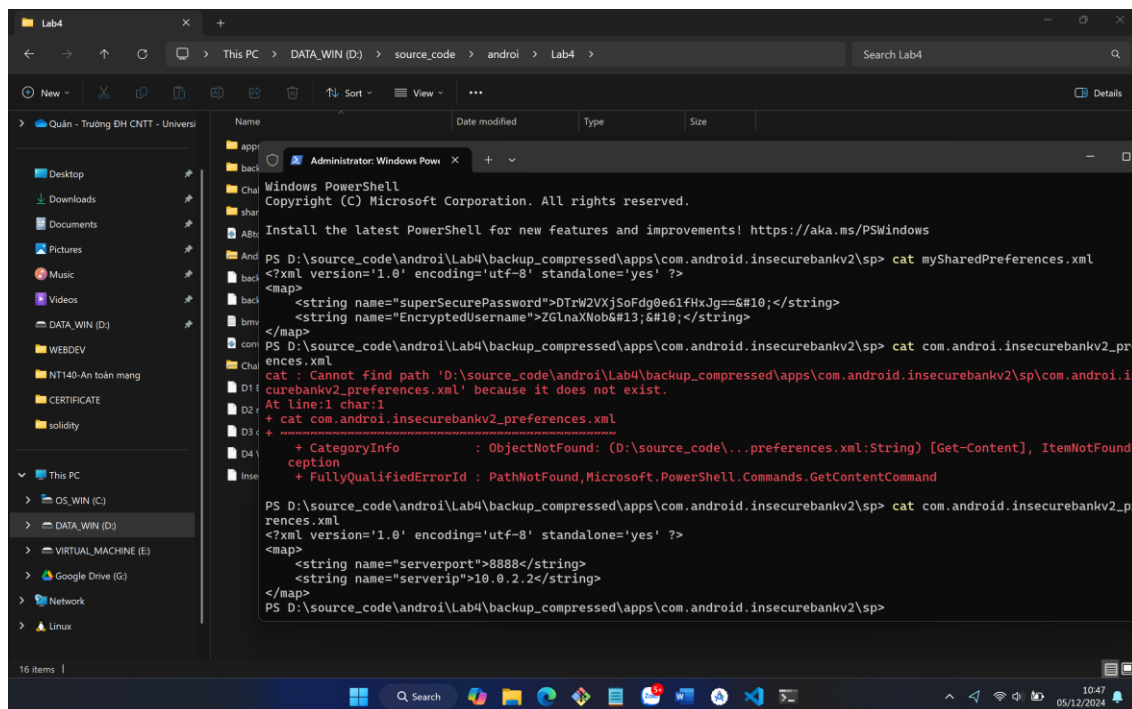
Mode                LastWriteTime         Length Name
----                -
d-----          12/5/2024  9:52 AM             Challenges
-a-----          12/4/2024  4:36 PM           26582 AndrolabServer.zip
-a-----          12/5/2024  10:12 AM              0 backup.ab
-a-----          12/4/2024  4:36 PM              21 bmw.txt
-a-----          12/4/2024  4:36 PM       17288810 Challenges.zip
-a-----          12/4/2024  4:36 PM       8330631 D1 EVABSV5.apk
-a-----          12/4/2024  4:36 PM       5469795 D2 netsight.apk
-a-----          12/4/2024  4:36 PM       1662615 D3 clickthelock.apk
-a-----          12/4/2024  4:36 PM       3628995 D4 Video Player.apk
-a-----          12/4/2024  4:36 PM       3462429 InsecureBankv2.apk

PS D:\source_code\androi\Lab4> wsl
DESKTOP-PS5C6MR:/mnt/host/d/source_code/androi/Lab4# ls
AndrolabServer.zip  Challenges.zip      D2 netsight.apk    D4 Video Player.apk  backup.ab
Challenges          D1 EVABSV5.apk    D3 clickthelock.apk InsecureBankv2.apk  bmw.txt
DESKTOP-PS5C6MR:/mnt/host/d/source_code/androi/Lab4# cat backup.ab
DESKTOP-PS5C6MR:/mnt/host/d/source_code/androi/Lab4# nano convert.py
~sh: nano: not found
```


- Khi kiểm tra thư mục ta thấy có file backup.ab, sau đó mở WSL dùng một file python để chuyển đổi định dạng có thể đọc.



- Giải nén file backup_compressed.tar và kiểm tra những thư mục đã được backup, một số trong đó đã được mã hoá.



Yêu cầu 5 Viết chương trình giải mã đoạn dữ liệu mã hoá (python3 chẳng hạn...)

- Tại đường dẫn `com/android/insecurebankv2/CryptoClass.class`, chứa các hàm mã hoá và giải mã.

```

14
15 public class CryptoClass {
16     String base64Text;
17     byte[] cipherData;
18     String cipherText;
19     byte[] ivBytes = new byte[] {0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0, 0};
20     String key = "This is the super secret key 123";
21     String plaintext;
22
23     public static byte[] aes256decrypt(byte[] var0, byte[] var1, byte[] var2) throws UnsupportedOperationException, NoSuchAlgorithmException {
24         IvParameterSpec var4 = new IvParameterSpec(var0);
25         SecretKeySpec var5 = new SecretKeySpec(var1, "AES");
26         Cipher var3 = Cipher.getInstance("AES/CBC/PKCS5Padding");
27         var3.init(2, var5, var4);
28         return var3.doFinal(var2);
29     }
30
31     public static byte[] aes256encrypt(byte[] var0, byte[] var1, byte[] var2) throws UnsupportedOperationException, NoSuchAlgorithmException {
32         IvParameterSpec var4 = new IvParameterSpec(var0);
33         SecretKeySpec var3 = new SecretKeySpec(var1, "AES");
34         Cipher var5 = Cipher.getInstance("AES/CBC/PKCS5Padding");
35         var5.init(1, var3, var4);
36         return var5.doFinal(var2);
37     }
38
39     public String aesDecryptedString(String var1) throws UnsupportedOperationException, InvalidKeyException, NoSuchAlgorithmException {
40         byte[] var2 = this.key.getBytes("UTF-8");
41         this.cipherData = aes256decrypt(this.ivBytes, var2, Base64.decode(var1.getBytes("UTF-8"), 0));

```


- Đoạn mã java trên dùng thuật toán AES-256 với mode CBC và đệm PKCS5Padding để mã hóa kèm theo đó là key và iv dùng để giải mã.

- Đoạn dữ liệu được mã hóa:

```
dducktai@ubuntu:~/BMW/backup_compressed/apps/com.android.insecurebankv2/sp$ cat mySharedPreferences.xml
<?xml version='1.0' encoding='utf-8' standalone='yes' ?>
<map>
  <string name="superSecurePassword">DTrW2VXjSoFdG0e61fHxJg==&#10;    </string>
  <string name="EncryptedUsername">ZGluZXNo&#13;&#10;    </string>
</map>
```

- Ta dễ dàng viết được file python để decrypt phần mật khẩu đã được mã hóa:

```
dducktai@ubuntu:~/BMW$ cat Bai5.py
from Crypto.Cipher import AES
import base64

def unpad(st):
    return st[ :- st[-1]]

def decrypt(key, cipher, iv):
    key = key.encode('utf-8')
    iv = iv.encode('utf-8')
    return AES.new(key, AES.MODE_CBC, iv).decrypt(cipher)

key = "This is the super secret key 123"
iv = '\x00' * 16
cipher = base64.b64decode("DTrW2VXjSoFdG0e61fHxJg == ")

result = unpad(decrypt(key, cipher, iv)).decode("utf-8")
print(result)
dducktai@ubuntu:~/BMW$ python3 Bai5.py
Dinesh@123$
```

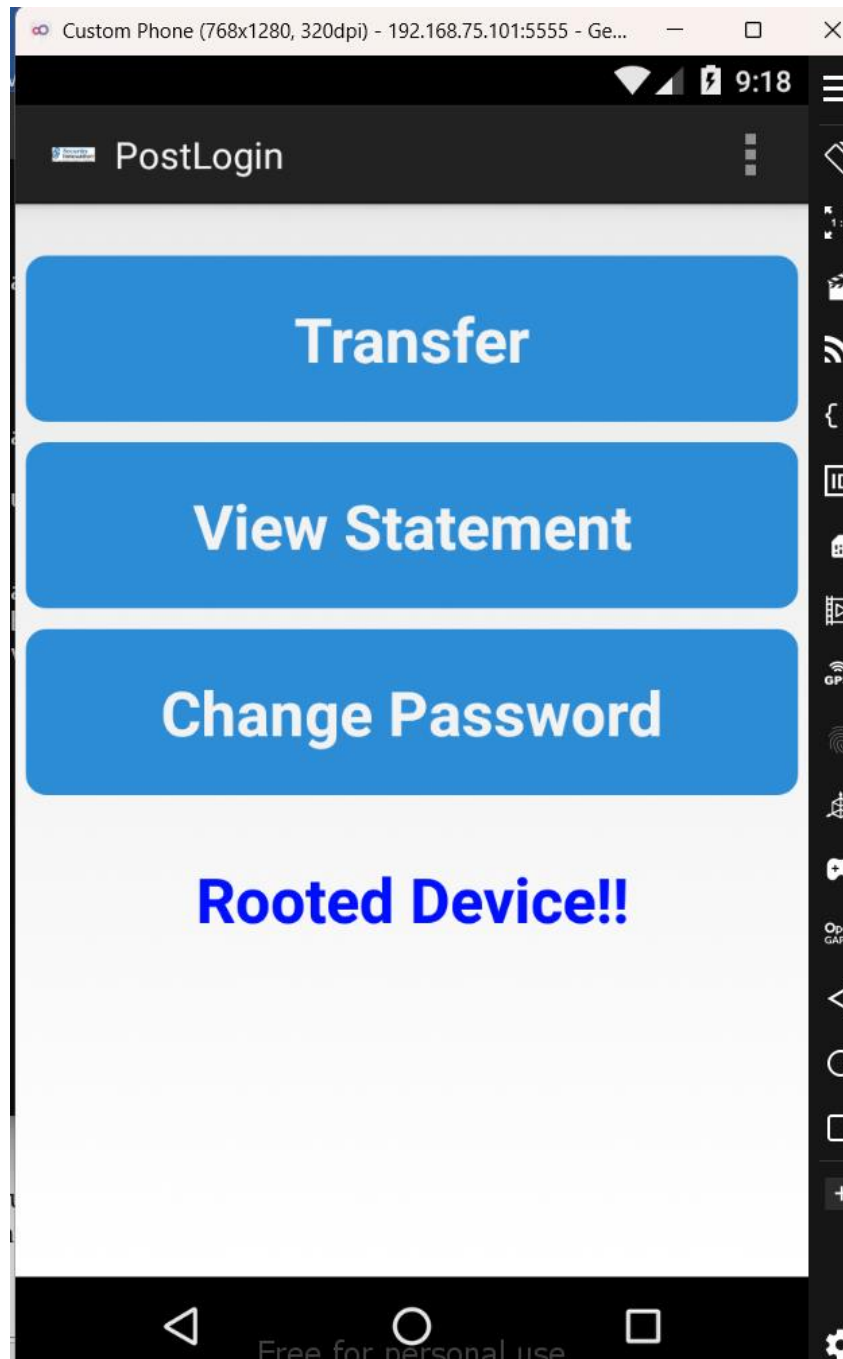
- Sau khi chạy chương trình, kết quả trả về đúng là mật khẩu của tài khoản dinesh: Dinesh@123\$

Yêu cầu 6 Sinh viên điều chỉnh mã nguồn ứng dụng sao cho luôn hiển thị trạng thái “Rooted Device!!” với bất kỳ trạng thái nào của thiết bị.

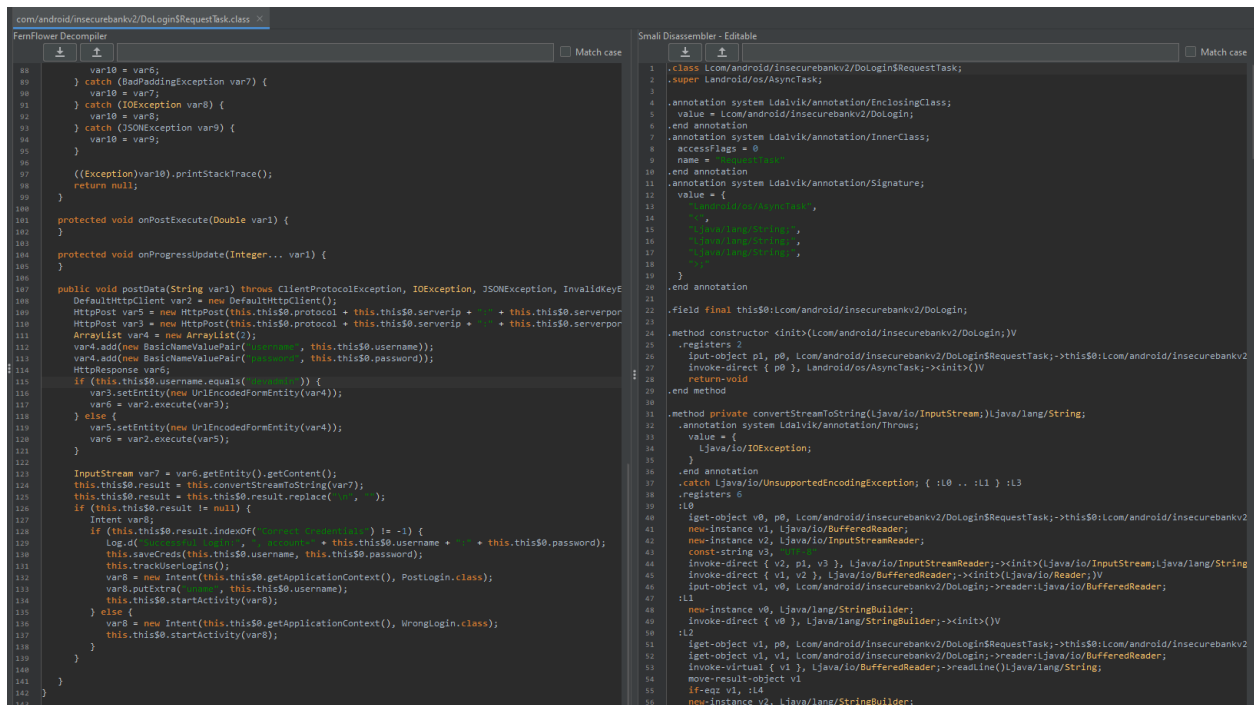
Thực hiện login mà không cần account.

```
D:\Bao Mat Web\platform-tools-latest-windows\platform-tools>adb shell
genymotion:/ # am start -n com.android.insecurebankv2/.PostLogin
Starting: Intent { cmp=com.android.insecurebankv2/.PostLogin }
genymotion:/ #
```

Thực hiện kiểm tra thì đã thấy login.

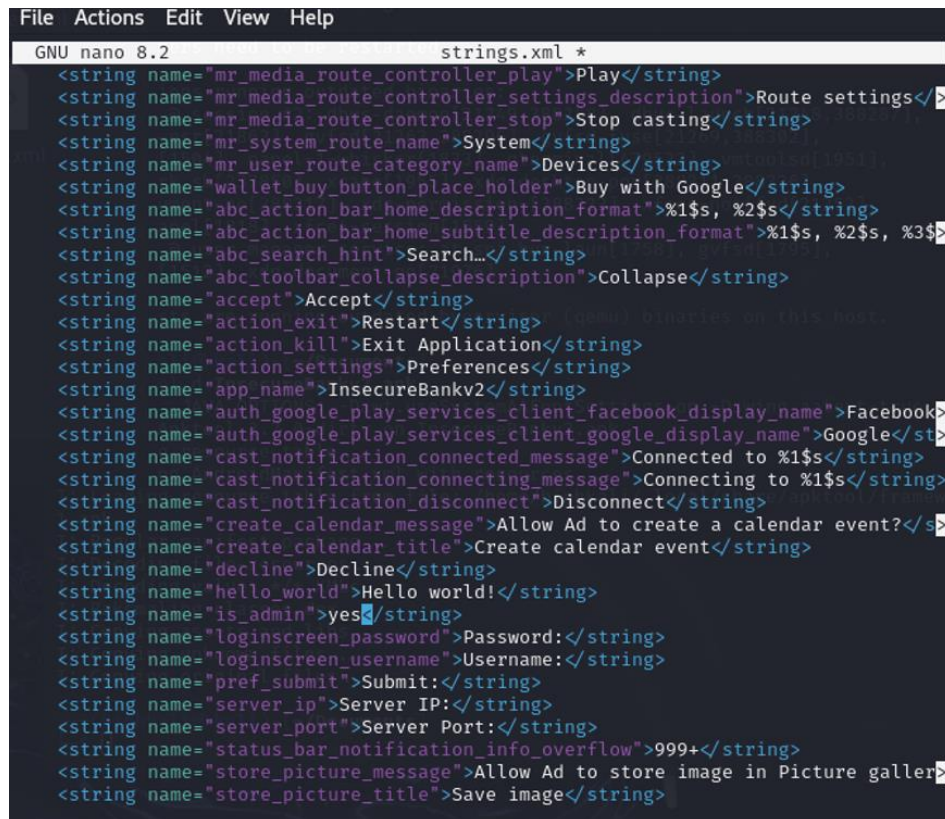


Đọc và phân tích code.



Thực hiện unzip file apk và xuất hiện ra các thành phần mở rộng.

Chỉnh leo quyền admin



Tạo file và thực hiện kí.

```
└─$ keytool -genkey -v -keystore InsecureBankv3.keystore -alias InsecureBankv3 -key
alg RSA -keysize
2048 -validity 10000
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
Illegal option: -
keytool -genkeypair [OPTION] ...
```

Generates a key pair

Options:

-alias <alias>	alias name of the entry to process
-keyalg <alg>	key algorithm name
-keysize <size>	key bit size
-groupname <name>	Group name. For example, an Elliptic Curve name.
-sigalg <alg>	signature algorithm name
-dname <name>	distinguished name
-startdate <date>	certificate validity start date/time
-ext <value>	X.509 extension
-validity <days>	validity number of days
-keypass <arg>	key password
-keystore <keystore>	keystore name
-signer <alias>	signer alias
-signerkeypass <arg>	signer key password
-storepass <arg>	keystore password
-storetype <type>	keystore type
-providername <name>	provider name
-addprovider <name>	add security provider by name (e.g. SunPKCS11)
[-providerarg <arg>]	configure argument for -addprovider
-providerclass <class>	add security provider by fully-qualified class name
[-providerarg <arg>]	configure argument for -providerclass
-providerpath <list>	provider classpath
-v	verbose output
-protected	password through protected mechanism

Use "keytool -?, -h, or --help" for this help message

zsh: command not found: 2048

```
└─$ keytool -genkey -v -keystore InsecureBankv3.keystore -alias InsecureBankv3 -key
alg RSA -keysize 2048 -validity 10000
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
```

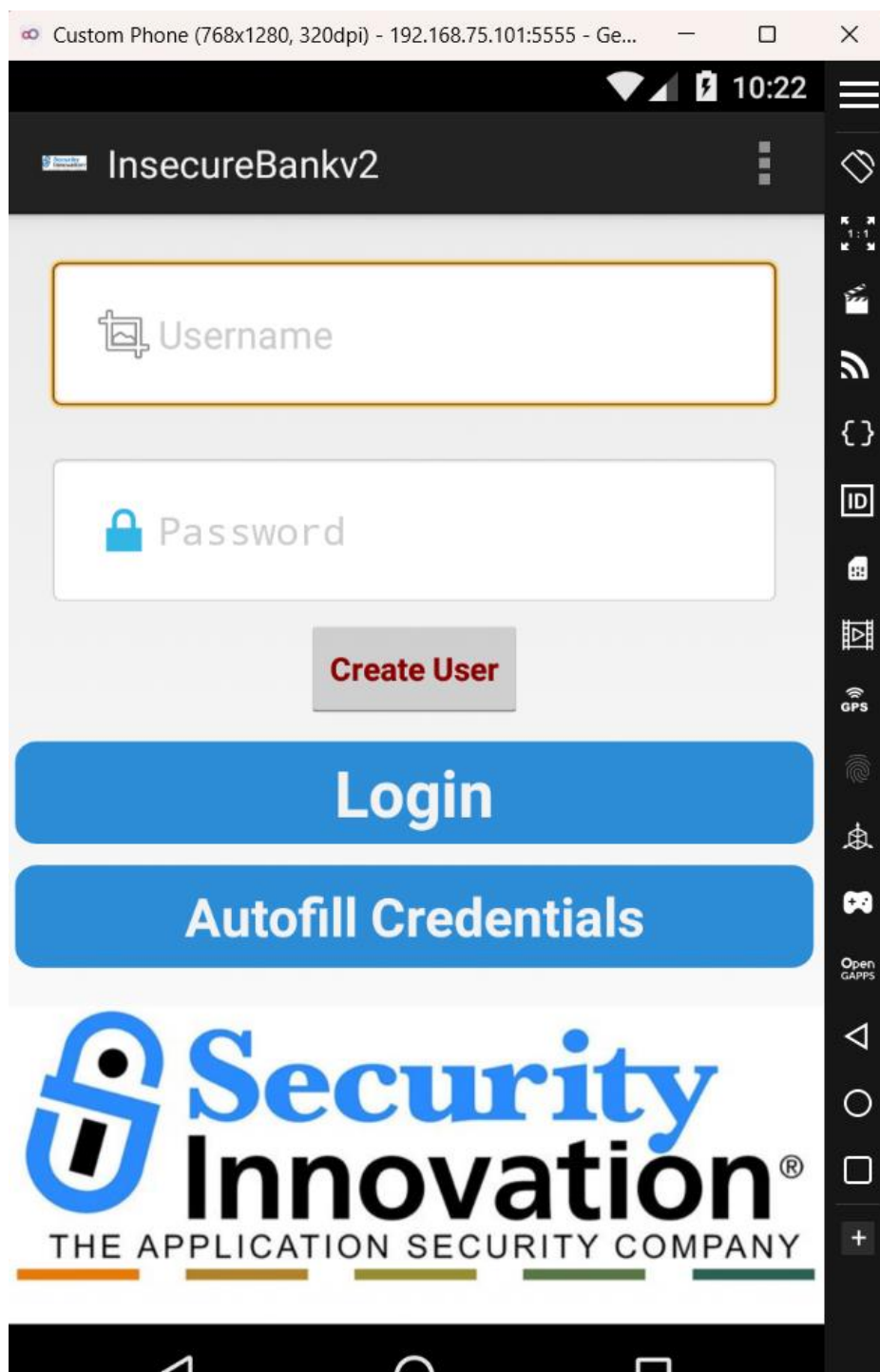
```
└─$ apksigner sign --ks InsecureBankv3.keystore InsecureBankv3.apk
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
Keystore password for signer #1:
```

Thực hiện cài đặt lại file.

```
D:\Bao Mat Web\platform-tools-latest-windows\platform-tools>adb install InsecureBankv3.apk
Performing Streamed Install
Success
```

```
D:\Bao Mat Web\platform-tools-latest-windows\platform-tools>|
```


Chương trình đã leo được quyền admin



Chỉn code luôn trả về Rooted Device trên mọi trường hợp.

```

.line 90
iget-object v1, p0, Lcom/android/insecurebankv2/PostLogin;→root_status:Landroid/widget/TextView;

const-string v2, "Rooted Device!!"

invoke-virtual {v1, v2}, Landroid/widget/TextView;→setText(Ljava/lang/CharSequence;)V

.line 96
:goto_1
return-void

.line 87
.end local v0    # "isrooted":Z
:cond_1
const/4 v0, 0x0

goto :goto_0

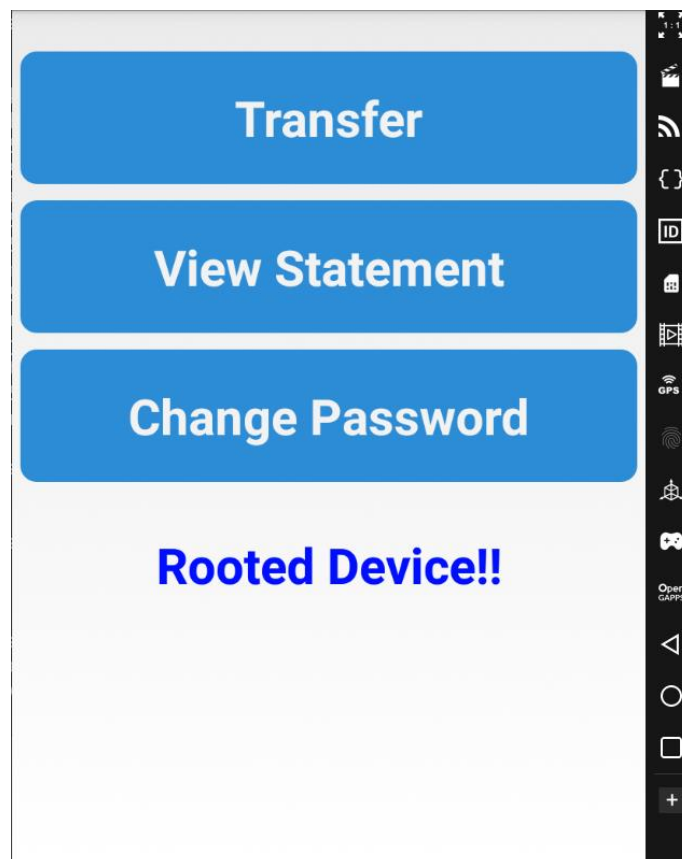
.line 94
.restart local v0    # "isrooted":Z
:cond_2
iget-object v1, p0, Lcom/android/insecurebankv2/PostLogin;→root_status:Landroid/widget/TextView;

const-string v2, "Rooted Device!!"

invoke-virtual {v1, v2}, Landroid/widget/TextView;→setText(Ljava/lang/CharSequence;)V

```

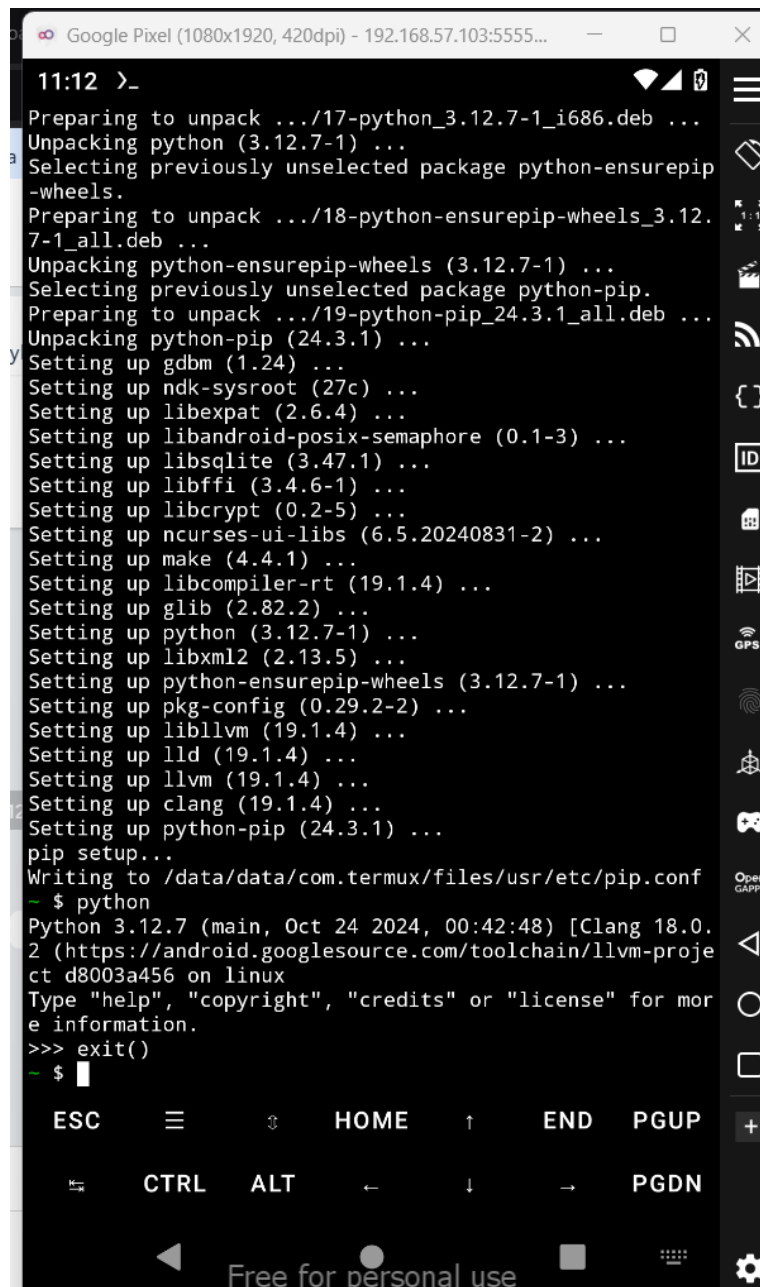
Kết quả.



Yêu cầu 7 Hoàn thiện đoạn code trên và demo.

Cài termux.apk vào để chuẩn bị cài python

```
PS C:\Users\tanph\Downloads\platform-tools> .\adb -s 192.168.57.103:5555 install C:\Users\tanph\Downloads\termux-app_v0.119.0-beta.1+apt-android-7-github-debug_x86.apk
Performing Streamed Install
Success
```



```
Google Pixel (1080x1920, 420dpi) - 192.168.57.103:5555...
11:12 ~_
Preparing to unpack .../17-python_3.12.7-1_i686.deb ...
Unpacking python (3.12.7-1) ...
Selecting previously unselected package python-ensurepip
-wheels.
Preparing to unpack .../18-python-ensurepip-wheels_3.12.
7-1_all.deb ...
Unpacking python-ensurepip-wheels (3.12.7-1) ...
Selecting previously unselected package python-pip.
Preparing to unpack .../19-python-pip_24.3.1_all.deb ...
Unpacking python-pip (24.3.1) ...
Setting up gdbm (1.24) ...
Setting up ndk-sysroot (27c) ...
Setting up libexpat (2.6.4) ...
Setting up libandroid-posix-semaphore (0.1-3) ...
Setting up libsqlite (3.47.1) ...
Setting up libffi (3.4.6-1) ...
Setting up libcrypt (0.2-5) ...
Setting up ncurses-ui-libs (6.5.20240831-2) ...
Setting up make (4.4.1) ...
Setting up libcompiler-rt (19.1.4) ...
Setting up glib (2.82.2) ...
Setting up python (3.12.7-1) ...
Setting up libxml2 (2.13.5) ...
Setting up python-ensurepip-wheels (3.12.7-1) ...
Setting up pkg-config (0.29.2-2) ...
Setting up libllvm (19.1.4) ...
Setting up lld (19.1.4) ...
Setting up llvm (19.1.4) ...
Setting up clang (19.1.4) ...
Setting up python-pip (24.3.1) ...
pip setup...
Writing to /data/data/com.termux/files/usr/etc/pip.conf
~ $ python
Python 3.12.7 (main, Oct 24 2024, 00:42:48) [Clang 18.0.
2 (https://android.googlesource.com/toolchain/llvm-proje
ct d8003a456 on linux
Type "help", "copyright", "credits" or "license" for mor
e information.
>>> exit()
~ $
```

Tải frida-server và đẩy vào android, set

```

PS C:\Users\tanph\Downloads\platform-tools> .\adb -s 192.168.57.103:5555 push "C:\Users\tanph\Desktop\Code\Bmw\frida-server-16.5.6-android-x86" /data/local/tmp/frida-server
C:\Users\tanph\Desktop\Code\Bmw\frida-server-16.5.6-android-x86>
PS C:\Users\tanph\Downloads\platform-tools> .\adb -s 192.168.57.103:5555 shell
vbox86p:/ # cd data/local/tmp
vbox86p:/data/local/tmp # ls
frida-server
vbox86p:/data/local/tmp # cd frida-server/
vbox86p:/data/local/tmp/frida-server # ls
frida-server-16.5.6-android-x86
vbox86p:/data/local/tmp/frida-server # chmod 777 frida-server-16.5.6-android-x86
vbox86p:/data/local/tmp/frida-server #

```

Chạy file python

```

GNU nano 8.2 task7.py
import frida
import time

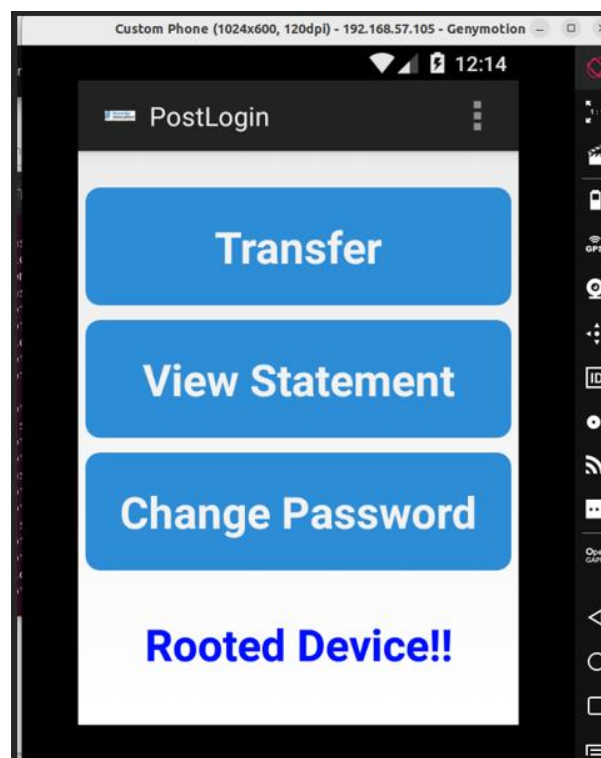
device = frida.get_usb_device()
pid = device.spawn("com.android.insecurebankv2")
device.resume(pid)
time.sleep(1) # Sleep 1 to avoid crash (sometimes)
session = device.attach(pid)

hook_script = """
Java.perform(function () {
    console.log("Inside the hook_script");
    var PostLogin = Java.use('com.android.insecurebankv2.PostLogin');
    var doesSuperuserApkExist = PostLogin.doesSuperuserApkExist;
    doesSuperuserApkExist.implementation = function (s) {
        console.log("Hooking Success");
        return true;
    };
});
"""

script = session.create_script(hook_script)
script.load()
input('...') # Prevent terminate

```

Như vậy chạy thành công:

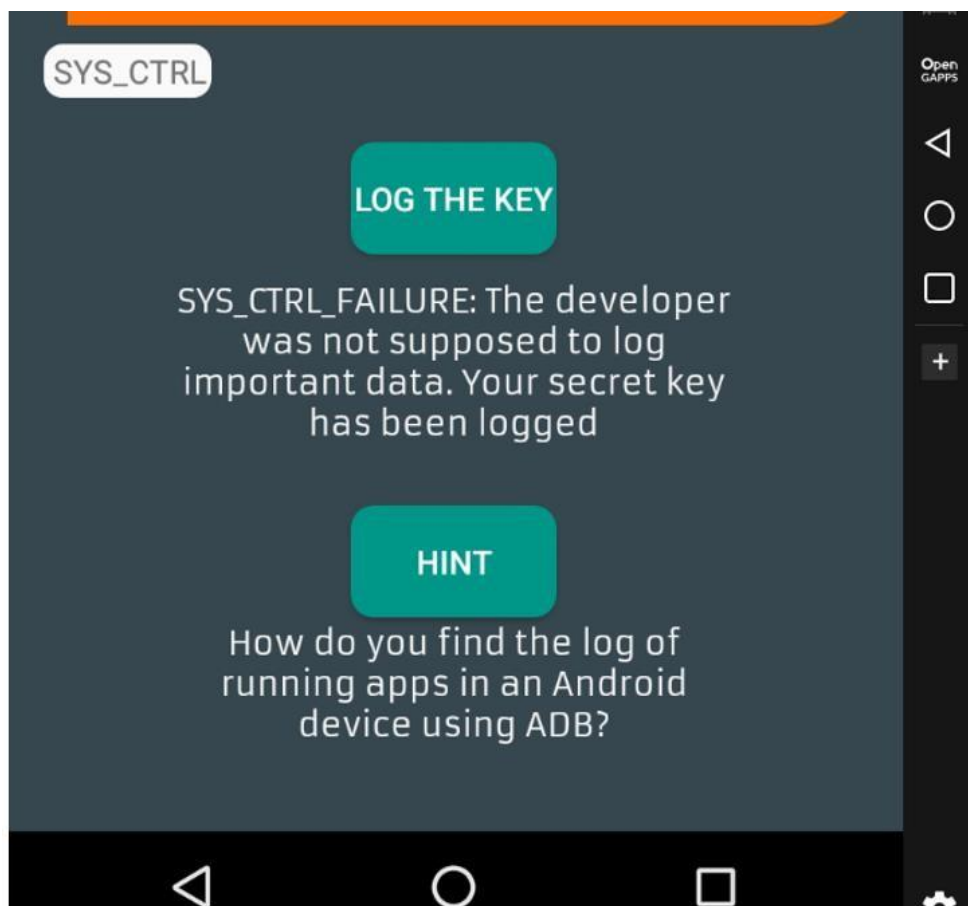


PHẦN II. CHALLENGES CTF

Challenge 1: 12 levels

Level 1:

Đầu tiên ta sử dụng lệnh **log cat** để thực hiện quá trình xem log. Và nhấn vào nút **log the key** trên ứng dụng.



```
Command Prompt - adb logc x + v
00:13:10:85:fe:01 rssi=-50 f=2447 sc=60 link=2 tx=2.1, 0.0, 0.0 rx=0.0 bcn=0 [on:0 tx:0 rx:0 period:3008] from screen [
on:0 period:595439160] score=60
11-13 10:07:39.869 810 810 W DnsResolver: resNetworkResult:android.system.ErrnoException: resNetworkResult failed: E
TIMEDOUT (Connection timed out)
11-13 10:07:39.869 810 810 W DnsResolver: resNetworkResult:android.system.ErrnoException: resNetworkResult failed: E
TIMEDOUT (Connection timed out)
11-13 10:07:39.869 810 810 W DnsResolver: resNetworkResult:android.system.ErrnoException: resNetworkResult failed: E
TIMEDOUT (Connection timed out)
11-13 10:07:39.869 810 810 W DnsResolver: resNetworkResult:android.system.ErrnoException: resNetworkResult failed: E
TIMEDOUT (Connection timed out)
11-13 10:07:39.869 810 5167 D NetworkMonitor/100: PROBE_DNS connectivitycheck.gstatic.com 10022ms FAIL in type ADDRCON
FIG android.net.DnsResolver$DnsException: android.system.ErrnoException: resNetworkResult failed: ETIMEDOUT (Connection
timed out)
11-13 10:07:39.870 810 5166 D NetworkMonitor/100: PROBE_DNS www.google.com 10022ms FAIL in type ADDRCONFIG android.ne
t.DnsResolver$DnsException: android.system.ErrnoException: resNetworkResult failed: ETIMEDOUT (Connection timed out)
11-13 10:07:40.935 333 333 I RanchuHwc: validateDisplay: layer 39 CompositionType 4, fallback to device
11-13 10:07:40.963 2135 2135 D ** SYS_CTRL **: EVABS{logging_info_never_safe}
11-13 10:07:40.971 383 501 D AudioFlinger: mixer(0x7e38d57a59a0) throttle end: throttle time(34)
11-13 10:07:40.981 2135 2266 D EGL_emulation: app_time_stats: avg=18947.19ms min=9943.06ms max=27951.33ms count=2
11-13 10:07:40.985 333 333 I RanchuHwc: validateDisplay: layer 39 CompositionType 4, fallback to device
11-13 10:07:41.018 333 333 I RanchuHwc: validateDisplay: layer 39 CompositionType 4, fallback to device
11-13 10:07:41.036 333 333 I RanchuHwc: validateDisplay: layer 39 CompositionType 4, fallback to device
11-13 10:07:41.052 333 333 I RanchuHwc: validateDisplay: layer 39 CompositionType 4, fallback to device
11-13 10:07:41.069 333 333 I RanchuHwc: validateDisplay: layer 39 CompositionType 4, fallback to device
11-13 10:07:41.085 333 333 I RanchuHwc: validateDisplay: layer 39 CompositionType 4, fallback to device
11-13 10:07:41.103 333 333 I RanchuHwc: validateDisplay: layer 39 CompositionType 4, fallback to device
11-13 10:07:41.120 333 333 I RanchuHwc: validateDisplay: layer 39 CompositionType 4, fallback to device
11-13 10:07:41.136 333 333 I RanchuHwc: validateDisplay: layer 39 CompositionType 4, fallback to device
11-13 10:07:41.153 333 333 I RanchuHwc: validateDisplay: layer 39 CompositionType 4, fallback to device
11-13 10:07:41.169 333 333 I RanchuHwc: validateDisplay: layer 39 CompositionType 4, fallback to device
```

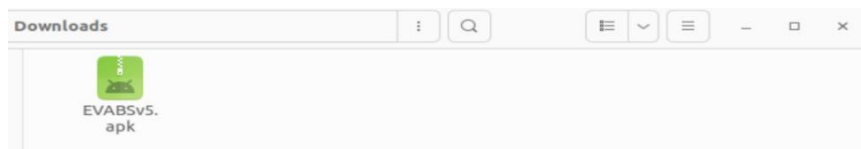
Ta có thể dùng lệnh lọc để tìm kiếm dễ dàng hơn :

```
C:\Users\ngocbao>adb logcat | findstr "EVABS{"
11-14 11:23:21.225 2074 2074 D ** SYS_CTRL **: EVABS{logging_info_never_safe}
```

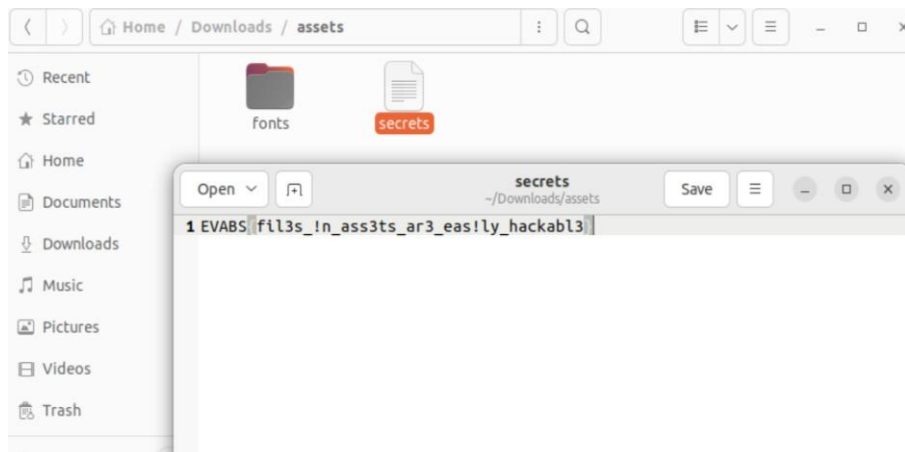
Ta sẽ tìm được Flag: EVABS{logging_info_never_safe}

Level 2:

Đầu tiên ta thực hiện unzip file

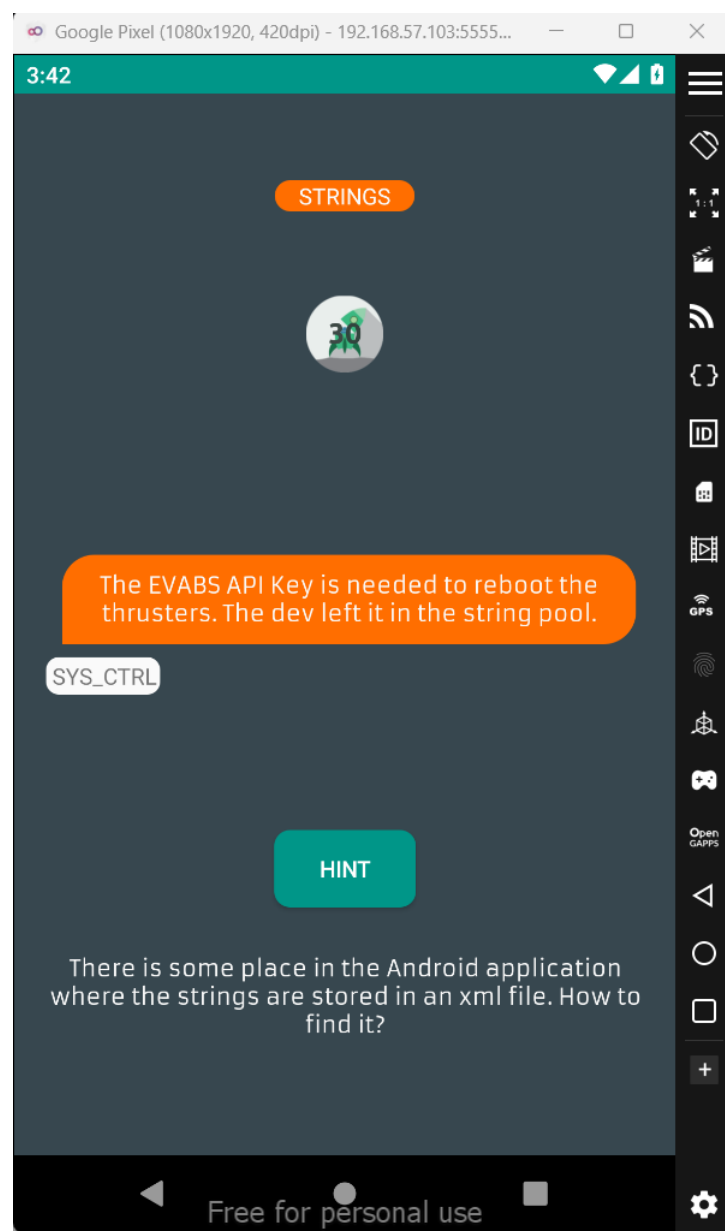


Thực hiện kiểm tra trong file assets thì ta có được flag theo gợi ý:



Flag: EVABS{fil3s_!n_ass3ts_ar3_eas!ly_hackabl3}

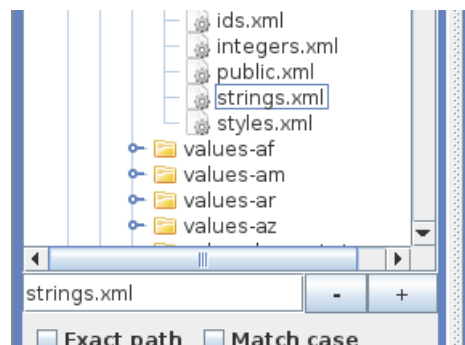
Level 3:



- Hint cho ta biết là flag đang được giấu ở trong 1 file android thường chứa những string
- Để xem được string trong file android thì ra có nhiều cách
- Ở đây ta dùng bytecode-viewer để xem

```
(kali㉿kali)-[~/Downloads]
$ java -jar Bytecode-Viewer-2.11.2.jar
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
Bytecode Viewer 2.11.2 [Fat Jar] - Created by @Konloch
```

Sử dụng lệnh này để có thể mở bytecode-viewer

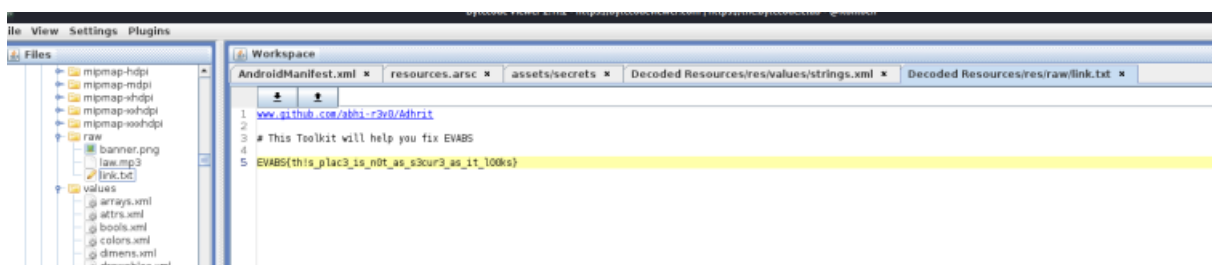
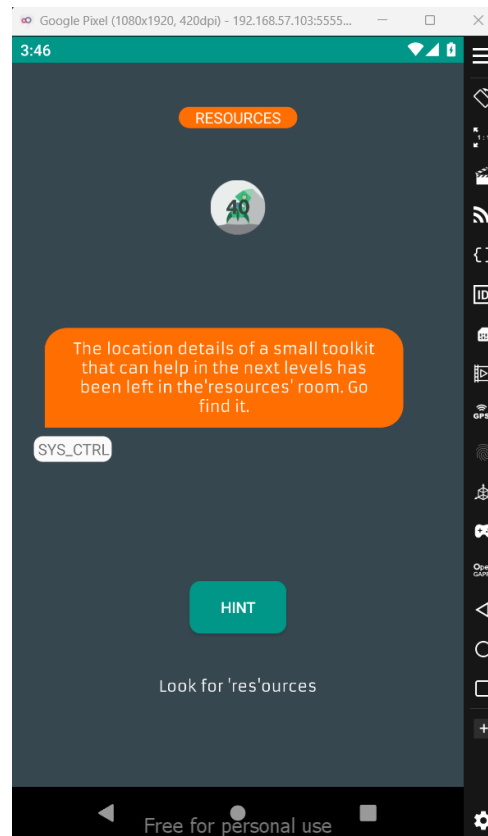


Ta kiểm file tên là “strings.xml” trong đây sẽ chứa những chuỗi có trong file apk

```
<string name="search_menu_title">Search</string>
<string name="section_format">Hello World from section: %1$d</string>
<string name="status_bar_notification_info_overflow">999+</string>
<string name="the Evans api key">EVABS{saf3ly_st0red_in_Strings?}</string>
<string name="title_activity_home">Home</string>
<string name="title_activity_launch">Launch</string>
<string name="title_activity_login">Sign in</string>
<string name="title_activity_splash">Splash</string>
<string name="title_activity_test">Test</string>
</resources>
```

Flag: EVABS{saf3ly_st0red_in_Strings?}

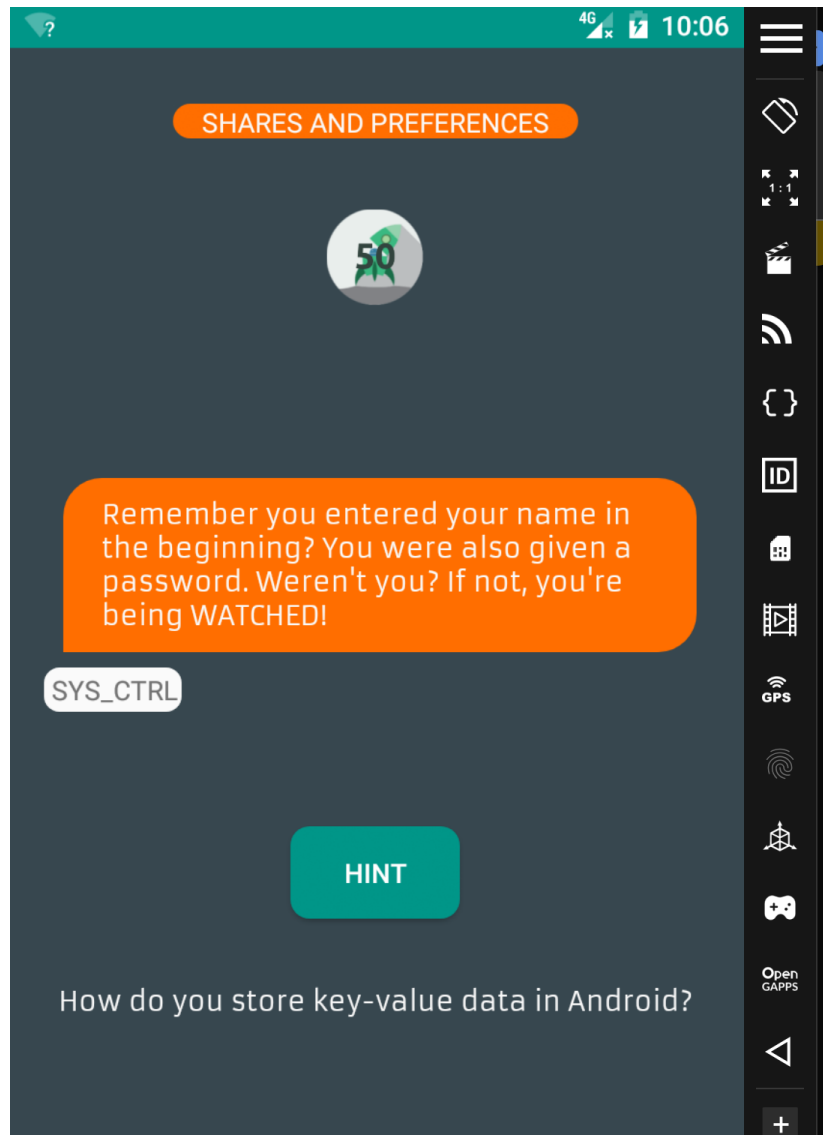
Level 4:



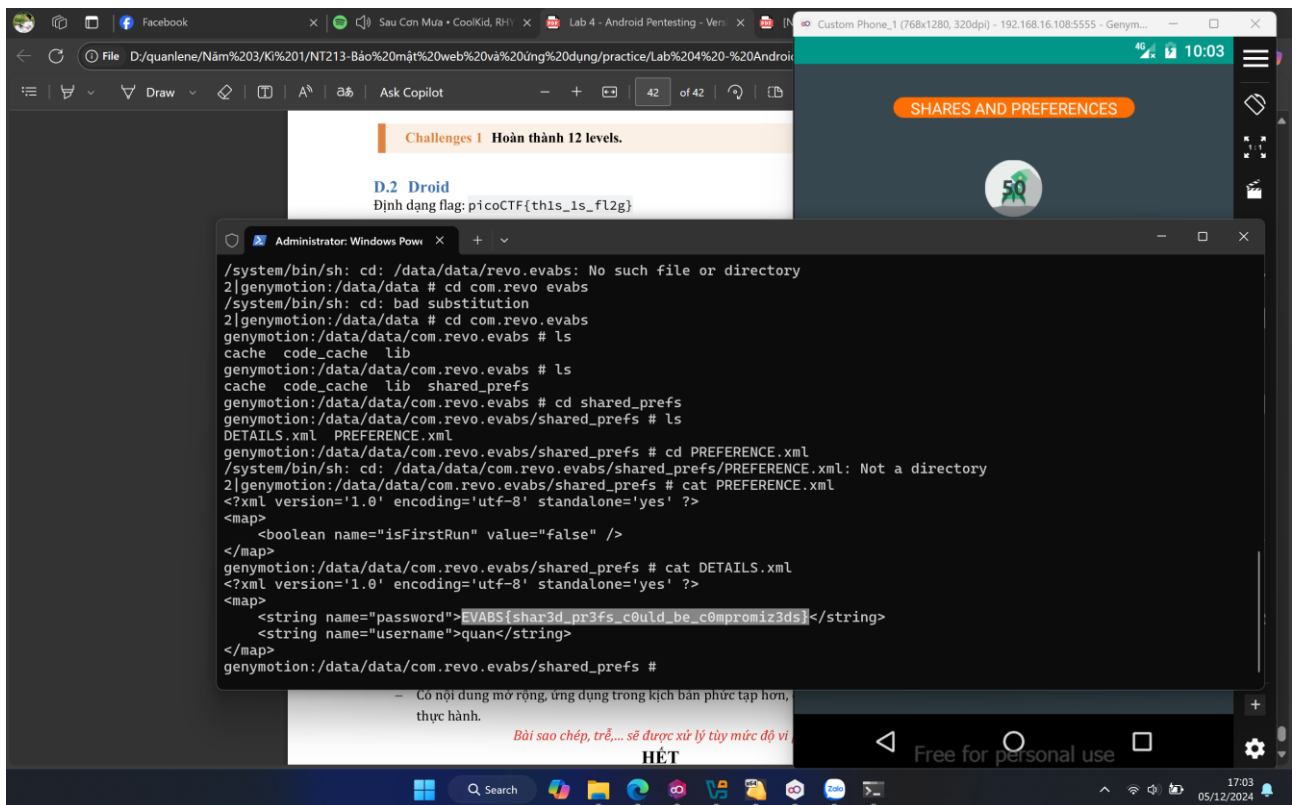
Tìm trong res và thấy thư mục res/raw/link.txt

Flag: EVABS{th!s_plac3_is_n0t_as_s3cur3_as_it_l00ks}

Level 5:

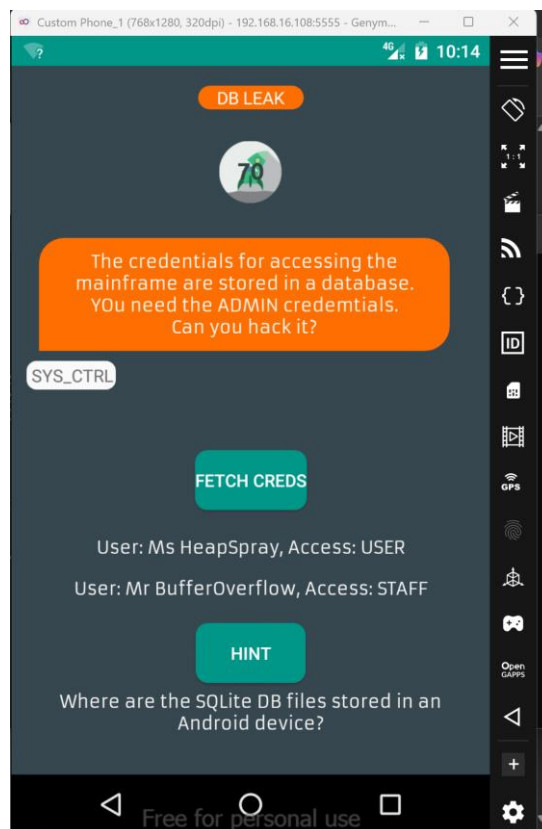


- Với gợi ý là share preferences thì ta cần phải connect vào máy và thư mục `/data/data/com.revo.evabs/shared`, sau đó ta sử dụng lệnh `grep -r "EVABS{"` thì ta có được flag

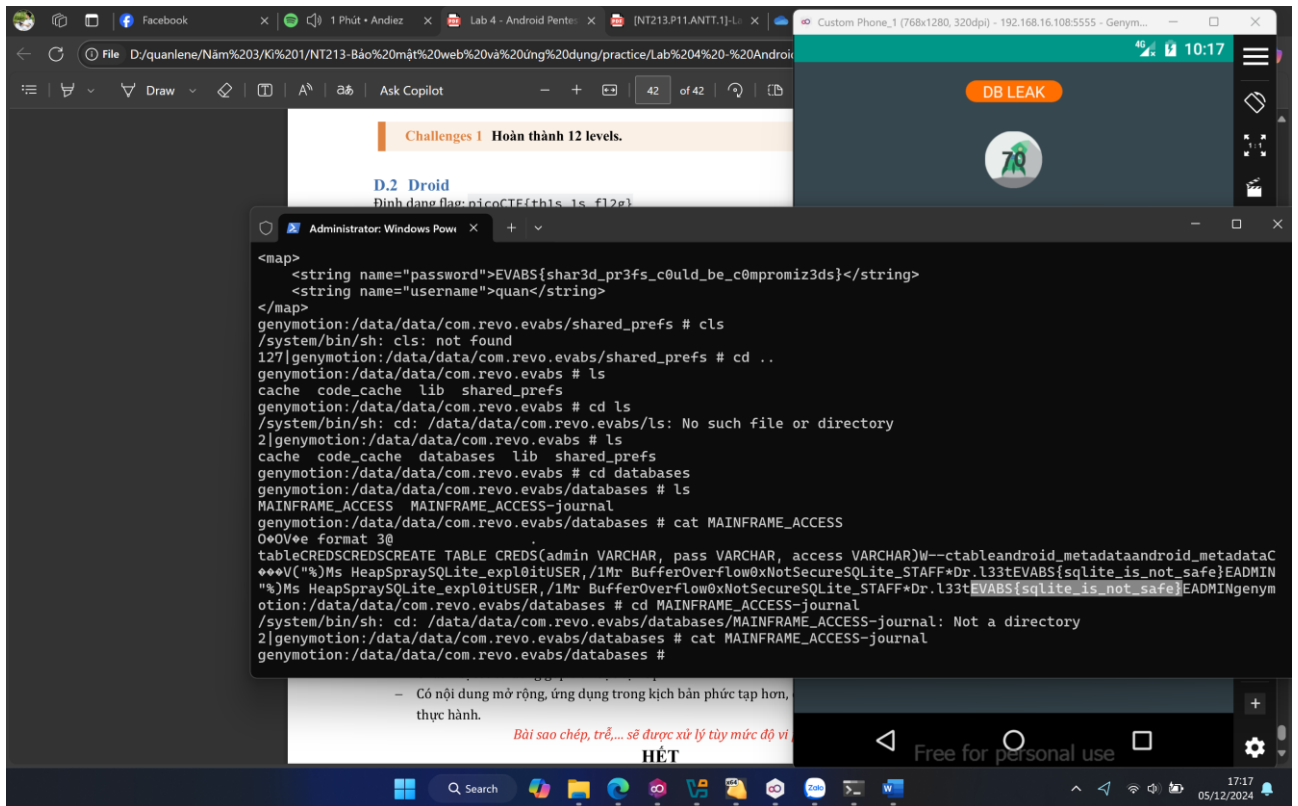


- Ta tìm thấy flag: EVABS{shar3d_pr3fs_c0uld_be_c0mpromiz3ds}

Level 6:



- Ta vào folder /data/data/com.revo.evabs/databases thì ta có MAINFRAME_ACCESS.
- Dùng lệnh cat MAINFRAME_ACCESS để đọc nội dung trong file và tìm flag.



- Ta tìm được flag: EVABS{sqlite_is_not_safe}

Level 7:

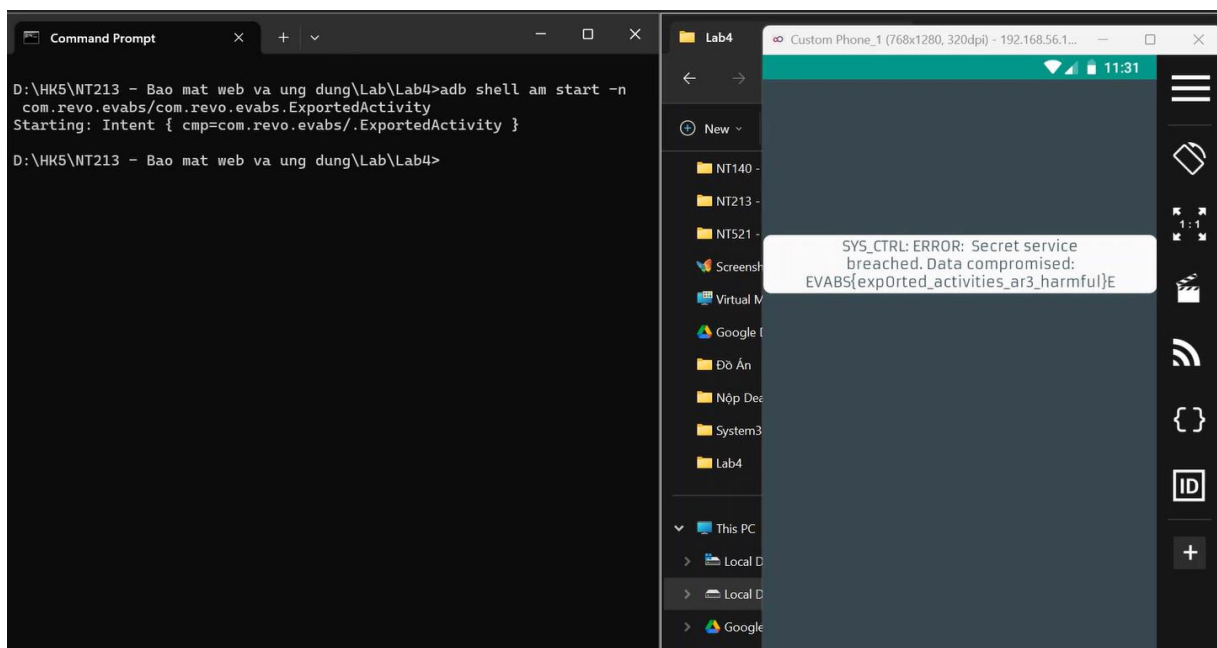
- Thực hiện kiểm tra file AndroidManifest.xml, ta có được thông tin về activity ExportedActivity:

```

dducktai@ubuntu:~/BMW/EVABSV5$ ls
AndroidManifest.xml  apktool.yml  assets  lib  original  res  smali  unknown
dducktai@ubuntu:~/BMW/EVABSV5$ cat AndroidManifest.xml
<?xml version="1.0" encoding="utf-8" standalone="no"?><manifest xmlns:android="http://
schemas.android.com/apk/res/android" package="com.revo.evabs">
    <uses-permission android:name="android.permission.INTERNET"/>
    <application android:allowBackup="false" android:debuggable="true" android:icon="@
mipmap/ic_launcher" android:label="@string/app_name" android:roundIcon="@mipmap/ic_lau
ncher_round" android:supportsRtl="true" android:theme="@style/AppTheme">
        <activity android:exported="true" android:name="com.revo.evabs.ExportedActivit
y"/>
        <activity android:name="com.revo.evabs.Frida1"/>
        <activity android:name="com.revo.evabs.FileRead"/>
        <activity android:name="com.revo.evabs.DebugMe"/>
        <activity android:name="com.revo.evabs.Welcome"/>
        <activity android:name="com.revo.evabs.ChallengeList" android:parentActivityNa
me="com.revo.evabs.Launch">

```

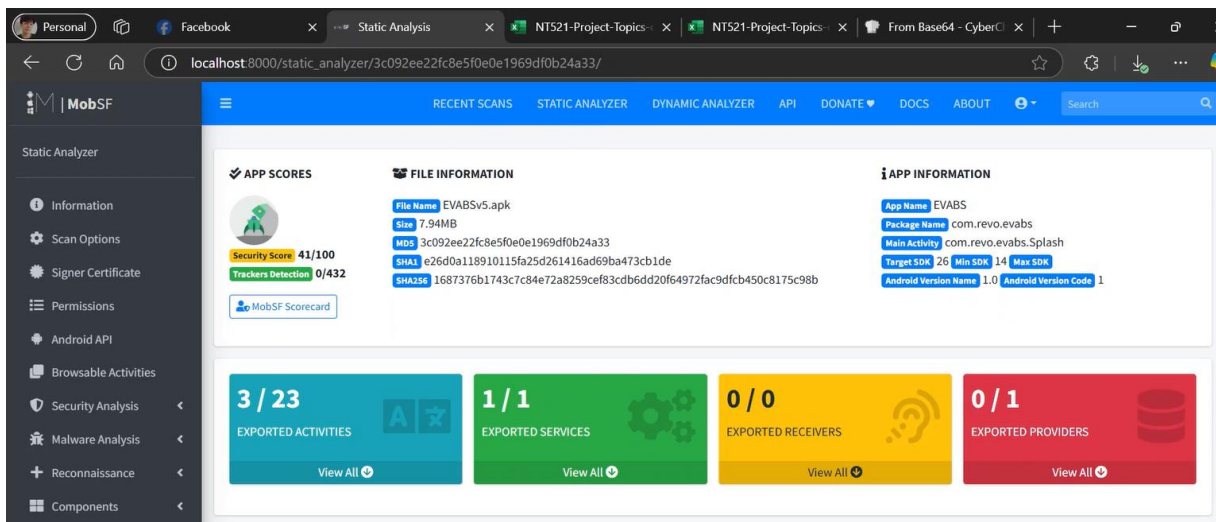
- Với thông tin này ta sẽ thực hiện trigger để xem thông tin về các ExportedActivity với lệnh như console bên dưới, và chương trình trên điện thoại để có được flag:



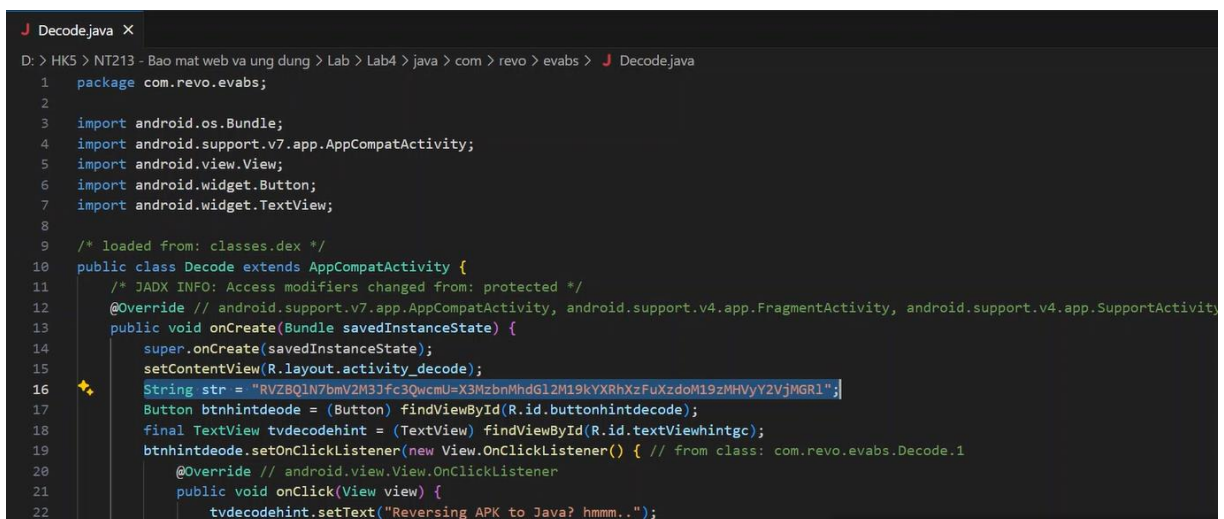
- Ta tìm được Flag: EVABS{exp0rted_activities_ar3_harmful}

Level 8:

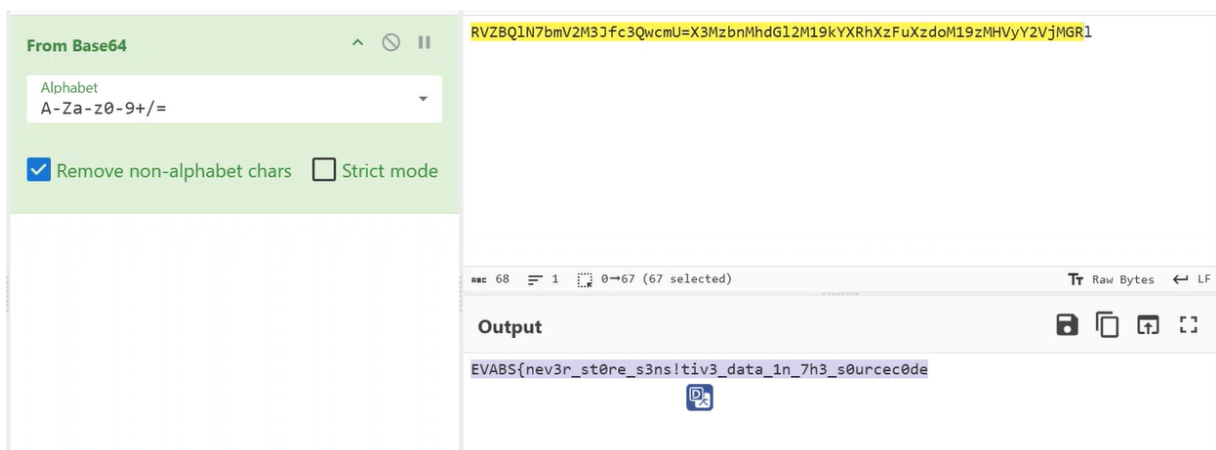
- Decompile code và tải code java về:



- Xem code của file Decode.java thì ta thấy cipher text ở dạng base64:



- Decode và được kết quả:



- Ta được Flag: EVABS{nev3r_st0re_s3ns!tiv3_data_1n_7h3_s0urcec0de}

Level 9:

- Sử dụng apktool để decompile file apk gốc, tiến hành thực hành tìm kiếm mã nguồn của level này:

```
SmaliInject$2.smali
Tệp  Chỉnh sửa  Dạng xem
.end method

# virtual methods
.method public onClick(Landroid/view/View;)V
    .locals 4
    .param p1, "view"    # Landroid/view/View;

    .line 38
    iget-object v0, p0, Lcom/revo/evabs/SmaliInject$2; -> this$0:Lcom/revo/evabs/SmaliInject;
    invoke-virtual {v0, Lcom/revo/evabs/SmaliInject; -> stringFromSmali()Ljava/lang/String;
    move-result-object v0

    .line 40
    .local v0, "ctrl":Ljava/lang/String;
    iget-object v1, p0, Lcom/revo/evabs/SmaliInject$2; -> this$0:Lcom/revo/evabs/SmaliInject;
    iget-object v1, v1, Lcom/revo/evabs/SmaliInject; -> SIGNAL:Ljava/lang/String;
    const-string v2, "LAB_ON"
    invoke-virtual {v1, v2}, Ljava/lang/String; -> equals(Ljava/lang/Object;)Z
    move-result v1
    if-eqz v1, :cond_0

```

```
SmaliInject$2.smali
Tệp  Chỉnh sửa  Dạng xem
invoke-virtual {v2}, Ljava/lang/StringBuilder; -> toString()Ljava/lang/String;
move-result-object v2

invoke-virtual {v1, v2}, Landroid/widget/TextView; -> setText(Ljava/lang/CharSequence;)V
goto :goto_0

.line 46
:cond_0
iget-object v1, p0, Lcom/revo/evabs/SmaliInject$2; -> val$tvlaboff:Landroid/widget/TextView;
const-string v2, "SYS_CTRL_CODE: LAB_ON"
invoke-virtual {v1, v2}, Landroid/widget/TextView; -> setText(Ljava/lang/CharSequence;)V

.line 47
iget-object v1, p0, Lcom/revo/evabs/SmaliInject$2; -> val$labstat:Landroid/widget/TextView;
const-string v2, "SYS_CTRL: ACCESS_DENIED"
invoke-virtual {v1, v2}, Landroid/widget/TextView; -> setText(Ljava/lang/CharSequence;)V

.line 49
:goto_0

```

- Xóa 2 đoạn trên và sửa const-string v2, "SYS CTRL CODE: LAB_OFF" thành const-string v2, "SYS CTRL CODE: LAB_ON"
- Thực hiện tạo key, build lại file đã sửa thành ctf9.apk, ký file ctf9.apk rồi install lại:

```
D:\HMS\NT213 - Bao mat web va ung dung\Lab\Lab4>keytool -genkeypair -v -keystore key.keystore -alias CTF9 -keyalg RSA -keysize 2048 -validity 1000
Enter keystore password:
Re-enter new password:
Enter the distinguished name. Provide a single dot (.) to leave a sub-component empty or press ENTER to use the default value in braces.
What is your first and last name?
What is the name of your organizational unit?
What is the name of your organization?
What is the name of your City or Locality?
What is the name of your State or Province?
What is the two-letter country code for this unit?
Is CN=Unknown, OU=Unknown, O=Unknown, L=Unknown, ST=Unknown, C=Unknown correct?
[no]: yes
Generating 2,048 bit RSA key pair and self-signed certificate (SHA384withRSA) with a validity of 1,000 days
for: CN=Unknown, OU=Unknown, O=Unknown, L=Unknown, ST=Unknown, C=Unknown
[Storing key.keystore]

D:\HMS\NT213 - Bao mat web va ung dung\Lab\Lab4>apktool b EVABSV5 -o ctf9.apk
I: Using Apktool 2.10.0 with 8 thread(s).
I: Checking whether sources has changed...
I: Checking whether resources has changed...
I: Building resources...
I: Smaling smali folder into classes.dex...
I: Building apk file...
I: Copying unknown files/dir...
I: Built apk into: ctf9.apk

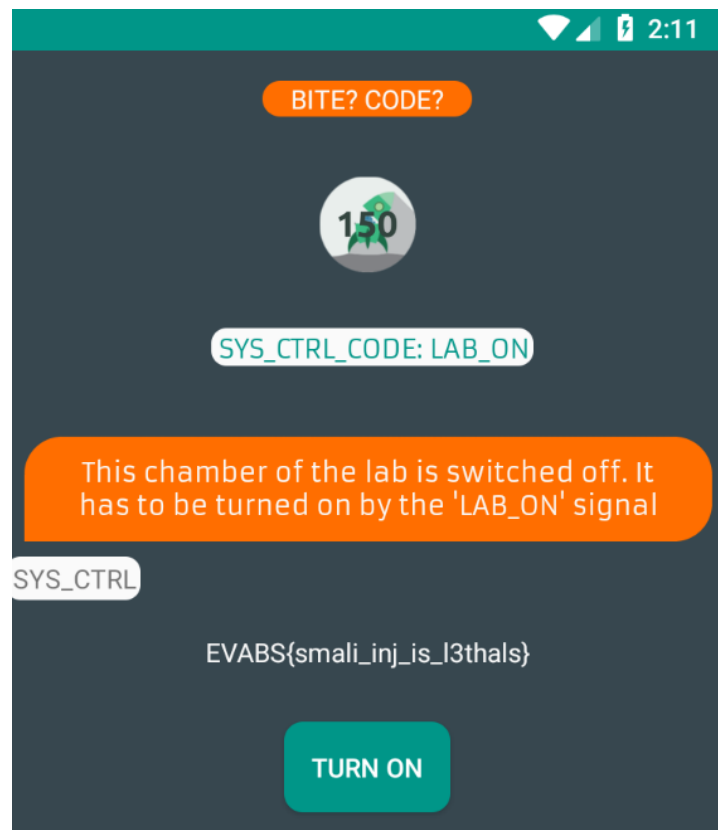
D:\HMS\NT213 - Bao mat web va ung dung\Lab\Lab4>jarsigner -keystore key.keystore -storepass 123456 ctf9.apk CTF9
jar signed.

Warning:
The signer's certificate is self-signed.

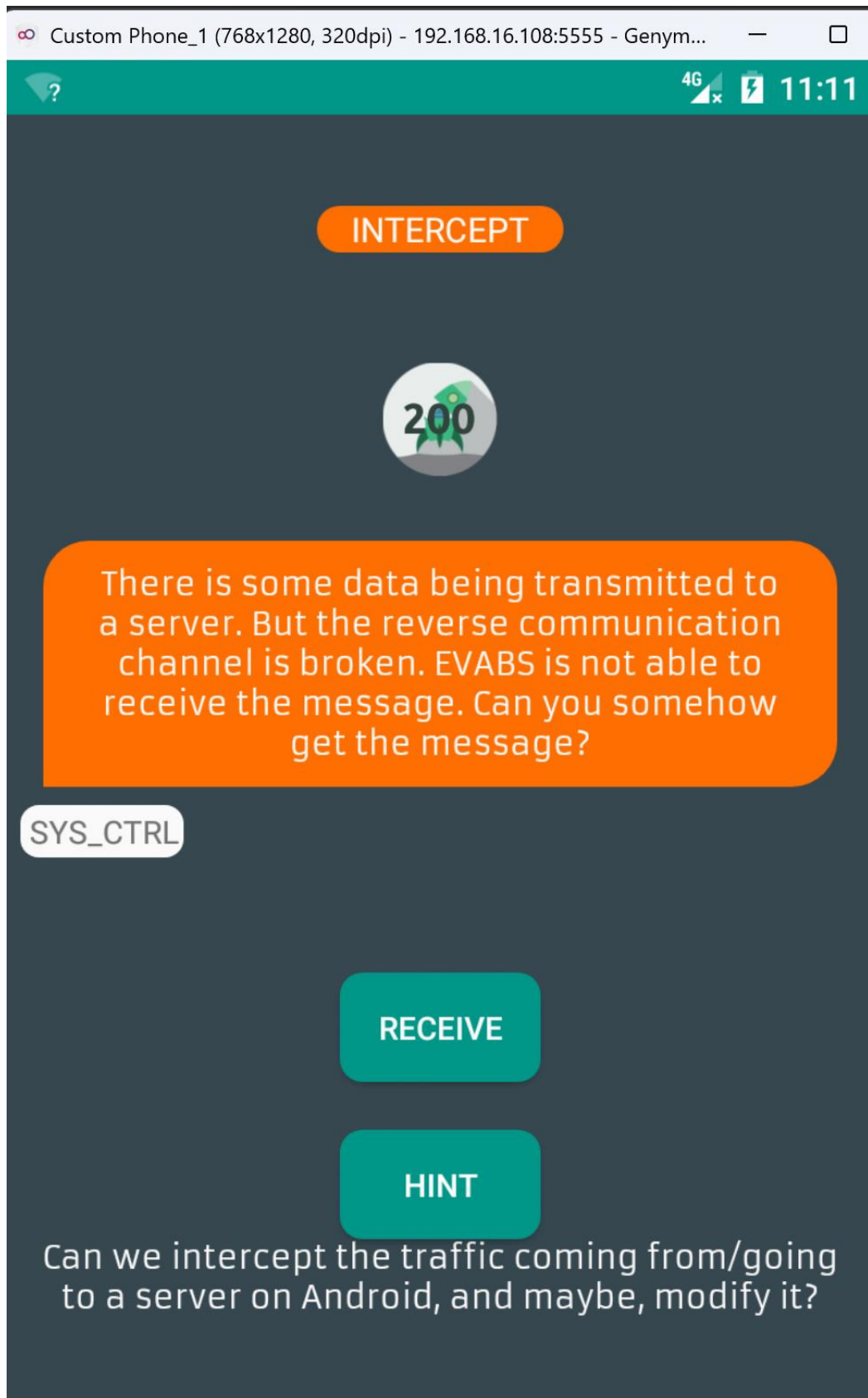
D:\HMS\NT213 - Bao mat web va ung dung\Lab\Lab4>adb install ctf9.apk
Performing Streamed Install
adb: failed to install ctf9.apk: Failure [INSTALL_FAILED_UPDATE_INCOMPATIBLE: Package com.revo.evabs signatures do not match the previously installed version; ignoring!]

D:\HMS\NT213 - Bao mat web va ung dung\Lab\Lab4>adb install ctf9.apk
Performing Streamed Install
Success
```

- Kết quả: Flat là EVABS{smali_inj_is_l3thals}



Level 10:



- Ta sẽ sử dụng OWASP ZAP để bắt gói tin

- Ta thực hiện các bước tạo cer, và kết nối OWASP với thiết bị Android
- Sau đó ta thực hiện bắt gói tin

104	Proxy	4/04/21 12:50:22 AM	GET	https://www.google.com/xjs/_/js/k=xjs.qs.es_4...	200 OK	249milisegun...	144.519bytes
111	Proxy	4/04/21 12:50:23 AM	GET	https://www.google.com/xjs/_/js/k=xjs.qs.es_4...	200 OK	124milisegun...	12.641bytes
119	Proxy	4/04/21 12:50:23 AM	POST	https://www.google.com/gen_204?atyp=i&ei=...	204 No Content	170milisegun...	0bytes
120	Proxy	4/04/21 12:50:23 AM	POST	https://www.google.com/gen_204?atyp=csi&ei=...	204 No Content	112milisegun...	0bytes
121	Proxy	4/04/21 12:50:23 AM	GET	https://www.google.com/client_204?cs=0	204 No Content	198milisegun...	0bytes
123	Proxy	4/04/21 12:50:23 AM	GET	https://www.google.com/async/bgasy?ei=mVN...	200 OK	230milisegun...	5.517bytes
131	Proxy	4/04/21 12:50:23 AM	GET	https://www.google.com/xjs/_/js/k=xjs.qs.es_4...	200 OK	125milisegun...	12.737bytes
146	Proxy	4/04/21 12:50:23 AM	GET	https://www.google.com/xjs/_/js/k=xjs.qs.es_4...	200 OK	121milisegun...	7.538bytes
153	Proxy	4/04/21 12:50:25 AM	POST	https://www.google.com/gen_204?atyp=csi&ei=...	204 No Content	107milisegun...	0bytes
154	Proxy	4/04/21 12:50:25 AM	GET	https://adservice.google.com/adsid/google/ui	204 No Content	156milisegun...	0bytes
155	Proxy	4/04/21 12:50:25 AM	POST	https://www.google.com/gen_204?atyp=i&ei=...	204 No Content	98milisegund...	0bytes
156	Proxy	4/04/21 12:50:43 AM	POST	https://evabsfiao.000webhostapp.com/reboot.o	200 OK	501milisegun...	33bytes

```

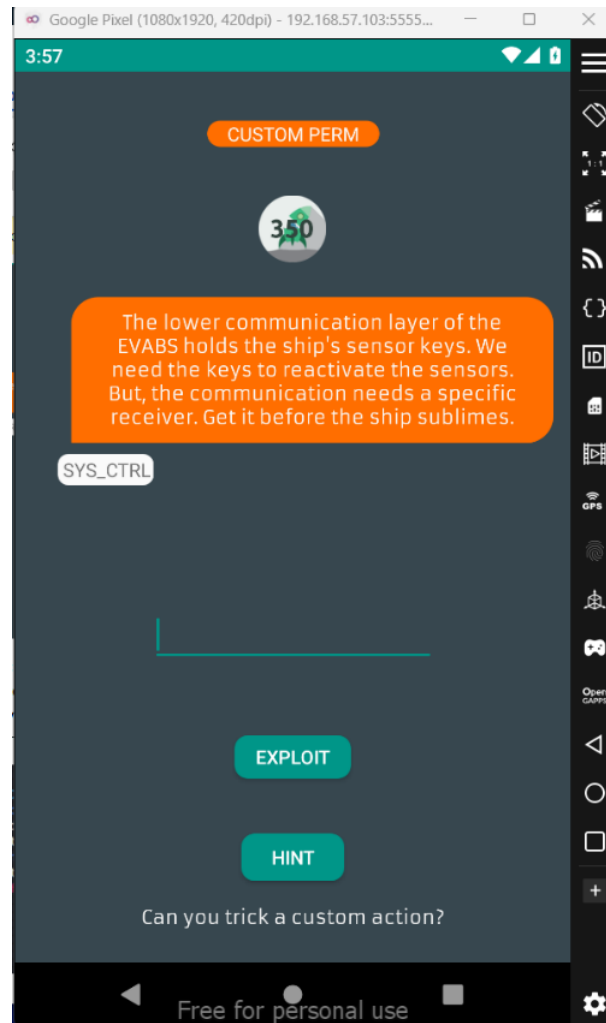
HTTP/1.1 200 OK
Date: Sun, 04 Apr 2021 05:50:41 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
Server: awex
X-Xss-Protection: 1; mode=block
X-Content-Type-Options: nosniff
X-Request-ID: 8b92b47716a7ee6e2c9f3b8fdb1bdab6

```

```
EVABS{Always_p!n_SSL_C3rtificate}
```

- Flag : EVABS{Always_p!n_SSL_C3rtificate}

Level 11:



In ra process điện thoại

PID	Name
3805	Calendar
3521	Clock
4401	EVABS
3839	Email
3881	Messaging
3784	Phone
3254	Settings
3931	Superuser
136	adbd
3422	android.ext.services
3608	android.process.acore
3655	android.process.media

Viết chương trình khai thác

```
import frida
import sys

def onMessage(message, data):
    print(message)

package = "EVABS"

jscode = """
Java.perform(function () {
    send("[.] Starting hooks android.content.Intent.putExtra");
    var intent = Java.use("android.content.Intent");
    intent.putExtra.overload("java.lang.String", "java.lang.String").implementation = function(param_1, param_2) {
        send("-->The Flag is: " + param_2);
    };
});
"""

process = frida.get_usb_device().attach(package)
script = process.create_script(jscode)
script.on("message", onMessage)
print("[+] Hooking successfully ", package)
script.load()
sys.stdin.read()
```

Mã JavaScript này thực hiện các bước sau:

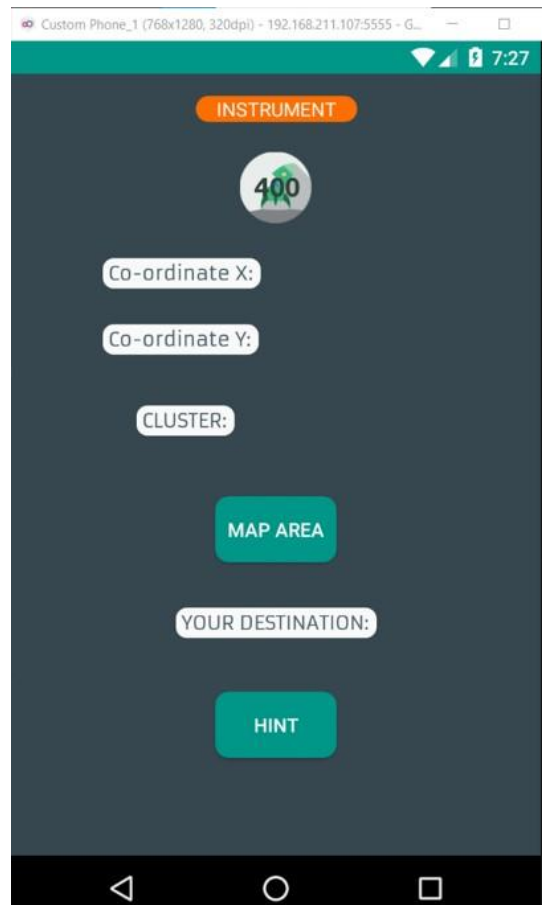
- + Sử dụng hàm `Java.perform()` để thực hiện mã JavaScript trong môi trường Java.
- + Gửi một thông điệp đến hàm `onMessage()` để thông báo rằng việc móc hàm đang được bắt đầu.
- + Sử dụng `Java.use()` để lấy đối tượng Java của lớp `"android.content.Intent"` và gán cho biến `intent`.
- + Sử dụng hàm `overload()` để chỉ định phiên bản chính xác của hàm `putExtra()` nhận hai tham số là chuỗi.
- + Ghi đè (override) hàm `putExtra()` để thay đổi hành vi của nó. Trong trường hợp này, khi hàm `putExtra()` được gọi, một thông điệp chứa cờ (flag) sẽ được gửi đến hàm `onMessage()` để in ra.

```
[+] Hooking successfully    EVABS
{'type': 'send', 'payload': '[.] Starting hooks android.content.Intent.putExtra'}
{'type': 'send', 'payload': '-->The Flag is: EVABS{always_verify_packag3sa}'}
{'type': 'error', 'description': 'Error: Implementation for putExtra expected return value compatible with android.content.Intent', 'stack': 'Error: Implementation for putExtra expected return value compatible with android.content.Intent\n at ne (frida/node_modules/frida-java-bridge/lib/class-factory.js:674)\n    at <anonymous> (frida/node_modules/frida-java-bridge/lib/class-factory.js:651)' 'fileName': 'frida/node_modules/
```

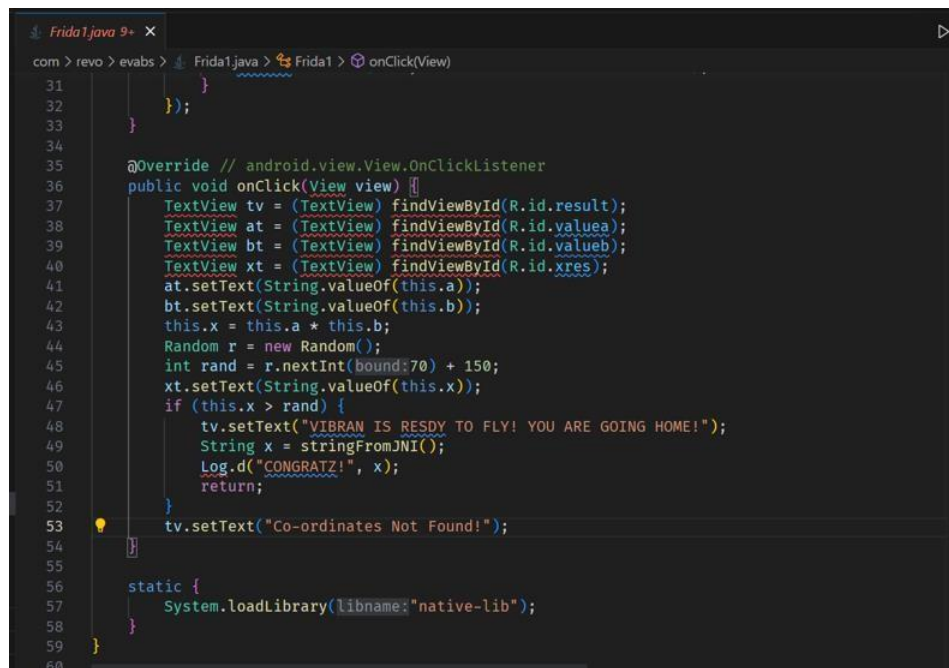
Flag **lag: EVABS{always_verify_packag3sa}**

Level 12:

Đầu tiên ta xem chương trình



Ta sẽ decompile code và xem thông tin.



```
31  
32  
33  
34  
35  
36  
37  
38  
39  
40  
41  
42  
43  
44  
45  
46  
47  
48  
49  
50  
51  
52  
53  
54  
55  
56  
57  
58  
59  
60  
  
@Override // android.view.View.OnClickListener  
public void onClick(View view) {  
    TextView tv = (TextView) findViewById(R.id.result);  
    TextView at = (TextView) findViewById(R.id.valuea);  
    TextView bt = (TextView) findViewById(R.id.valueb);  
    TextView xt = (TextView) findViewById(R.id.xres);  
    at.setText(String.valueOf(this.a));  
    bt.setText(String.valueOf(this.b));  
    this.x = this.a * this.b;  
    Random r = new Random();  
    int rand = r.nextInt(bound:70) + 150;  
    xt.setText(String.valueOf(this.x));  
    if (this.x > rand) {  
        tv.setText("VIBRAN IS RESDY TO FLY! YOU ARE GOING HOME!");  
        String x = stringFromJNI();  
        Log.d("CONGRATZ!", x);  
        return;  
    }  
    tv.setText("Co-ordinates Not Found!");  
}
```

Ta thấy được thông tin chính là $x = a * b$ với $a = 25$ và $b = 2$ và sử dụng x so sánh với 1 số random + 150, nếu $x > \text{random} + 150$ thì in thông tin Flag

Vậy ở bài này ta sẽ thực Hien code với việc truyền giá trị random vào sao cho luôn trả về là -150 để khi cộng với 150 thì bằng 0 và 0 thì luôn luôn nhỏ hơn $25 * 2$, thì khi ấy ta sẽ in được Flag.

Cuối cùng, chạy code python, mở log và nhấn vào nút Map Area ta sẽ tìm được Flag ở log

```

# import library
import frida
import sys

# implement the java code for hooking
javaCode = """
Java.perform(function () {
    send("[*] Starting hooks java.util.Random.nextInt");
    var random = Java.use("java.util.Random");
    random.nextInt.overload("int").implementation = function (var_1) {
        return -150;
    };
});
"""

# print the message
def printGetInfor(message, data):
    print(message)

# attach the process with pid change
# remember to change the pid
process = frida.get_usb_device().attach(2331)

# create the script with java code
script = process.create_script(javaCode)

# add the message handler to print the message
script.on("message", printGetInfor)

# start hooking
print("[*] Hooking")

# load the script
script.load()

# keep the script running to read the result
sys.stdin.read()

```

```

at 67.294ms
2331 2331 D ** SYS_CTRL **: EVABS{logging_info_never_safe}
2331 2338 I zygote : JIT allocated 56KB for compiled code of void android.view.View.<
2331 2331 D CONGRATZ!: EVABS{a_dynam1c_h00k}E

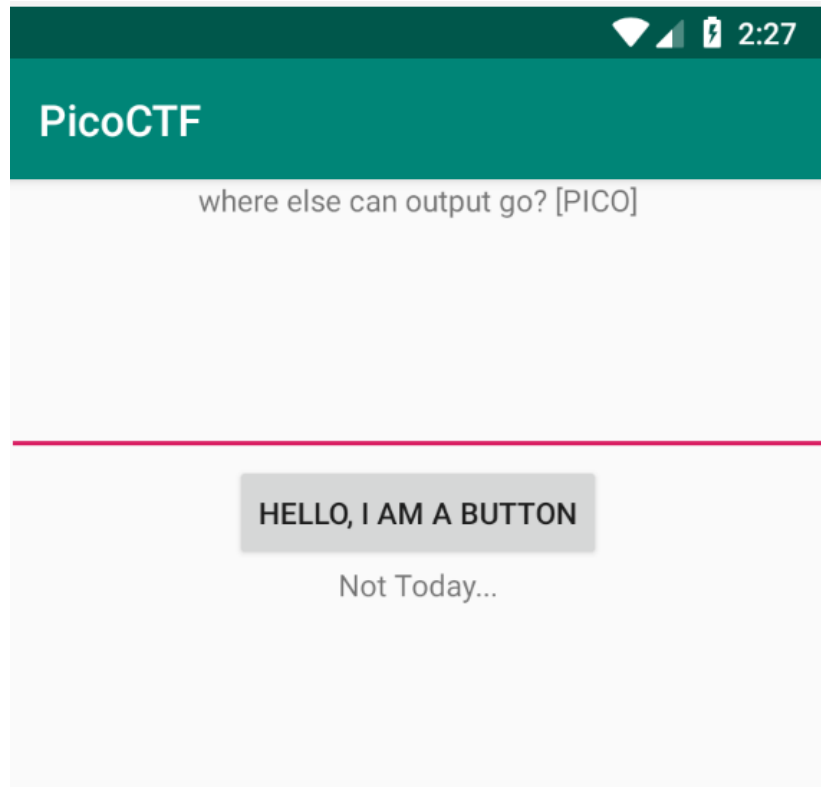
```

Flag: EVABS{a_dynam1c_h00k}

Challenge 2: 5 levels

Level 1:

- Tải app one.apk lên điện thoại ảo:



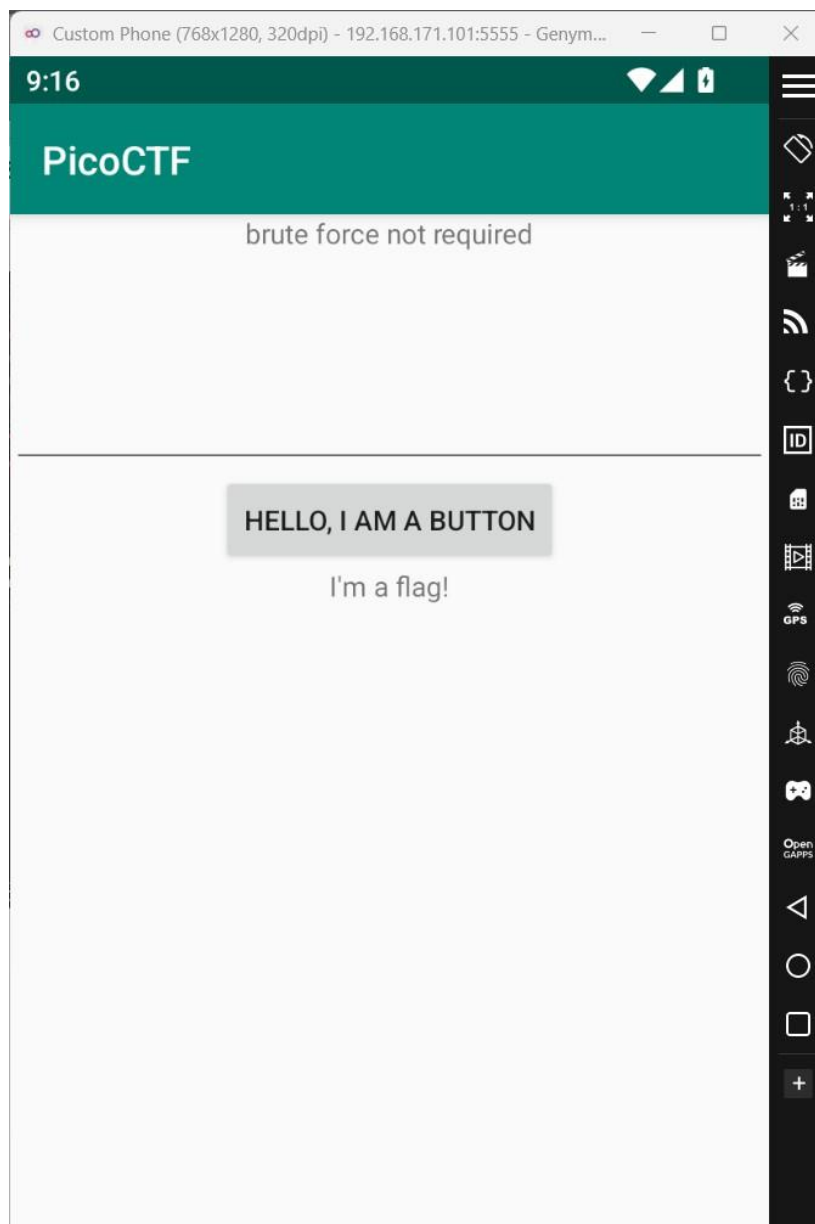
- Xem những log có chứa từ khóa “pico” bằng lệnh logcat grep “pico” *

```
Command Prompt - adb shell
v="sockfs" ino=12809 scontext=u:r:redis:s0 tcontext=u:r:redis:s0 tclass=tcp_socket permissive=1
12-05 02:28:28.878 212 212 I redis : type=1400 audit(0.0:1095): avc: denied { accept } for lport=6379 scontext=u:r:redis:s0 tcontext=u:r:redis:s0 tclass=tcp_socket permissive=1
12-05 02:28:28.878 212 212 I redis : type=1400 audit(0.0:1096): avc: denied { connectto } for path="/dev/socket/fwmarkd" scontext=u:r:redis:s0 tcontext=u:r:netd:s0 tclass=unix_stream_socket permissive=1
12-05 02:28:28.878 212 212 I redis : type=1400 audit(0.0:1097): avc: denied { setopt } for laddr=127.0.0.1 lport=6379 faddr=127.0.0.1 fport=35786 scontext=u:r:redis:s0 tcontext=u:r:redis:s0 tclass=tcp_socket permissive=1
12-05 02:29:00.005 456 470 E memtrack: Couldn't load memtrack module
12-05 02:29:00.005 456 470 W android.os.Debug: failed to get memory consumption info: -1
12-05 02:29:06.520 5665 5665 I PICO : picoCTF{a.moose.once.bit.my.sister}
12-05 02:29:06.545 217 249 W genymotion_audio: Not supplying enough data to HAL, expected position 24047520 , only wrote 24046560
12-05 02:29:09.771 217 250 W genymotion_audio: Not supplying enough data to HAL, expected position 24354224 , only wrote 24201360
12-05 02:29:16.653 456 470 I UsageStatsService: User[0] Flushing usage stats to disk
12-05 02:29:16.691 456 463 E eglCodecCommon: goldfish_dma_create_region: could not obtain fd to device! fd -1 errno=2
12-05 02:29:37.752 5665 5665 I PICO : picoCTF{a.moose.once.bit.my.sister}
12-05 02:29:37.759 217 249 W genymotion_audio: Not supplying enough data to HAL, expected position 24201591 , only wrote 24201360
```

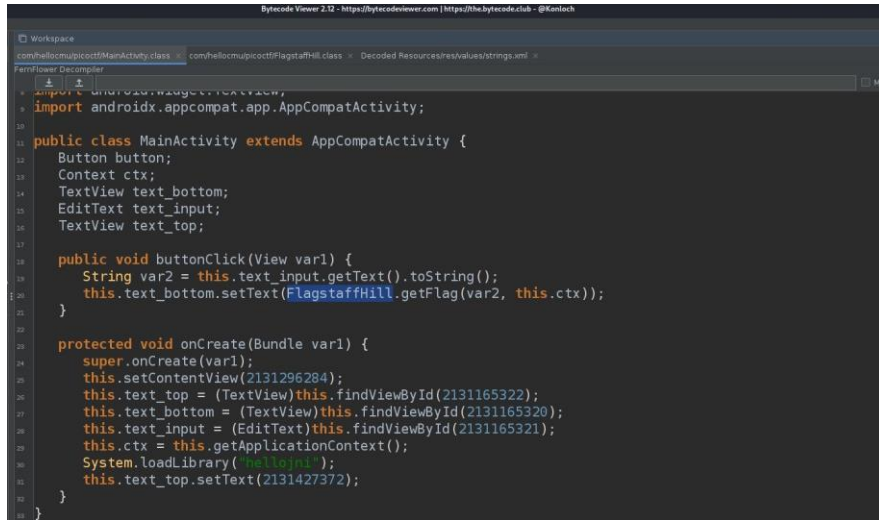
- Flat: picoCTF{a.moose.once.bit.my.sister}

Level 2:

- Tải app two.apk lên điện thoại ảo



- Sử dụng CodeByte Viewer để coi luồng thực thi chương trình



```

Bytecode Viewer 2.12 - https://bytecodeviewer.com | https://thebytecode.club - @Kontach
Workspace
com.hellocmu.picoctf.MainActivity.class  com.hellocmu.picoctf.FlagstaffHill.class  Decoded Resources/res/values/strings.xml
Fernflower Decompiler
import androidx.appcompat.widget.TextView;
import androidx.appcompat.app.AppCompatActivity;

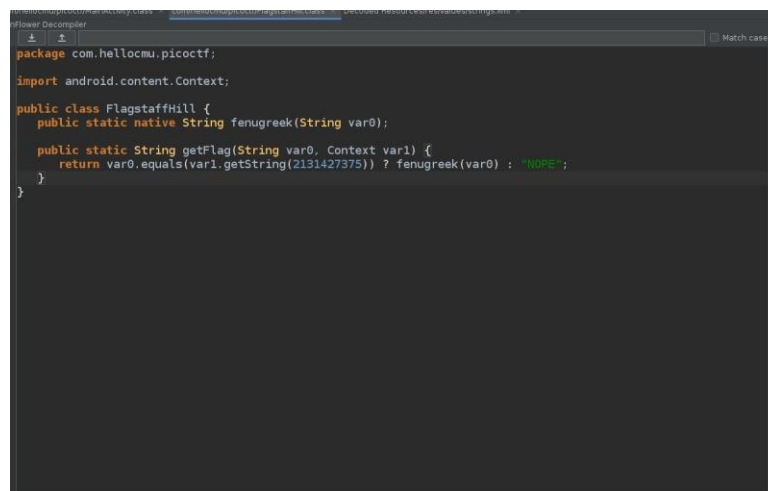
public class MainActivity extends AppCompatActivity {
    Button button;
    Context ctx;
    TextView text_bottom;
    EditText text_input;
    TextView text_top;

    public void buttonClick(View var1) {
        String var2 = this.text_input.getText().toString();
        this.text_bottom.setText(FlagstaffHill.getFlag(var2, this.ctx));
    }

    protected void onCreate(Bundle var1) {
        super.onCreate(var1);
        this setContentView(2131296284);
        this.text_top = (TextView)this.findViewById(2131165322);
        this.text_bottom = (TextView)this.findViewById(2131165320);
        this.text_input = (EditText)this.findViewById(2131165321);
        this.ctx = this.getApplicationContext();
        System.loadLibrary("hellojni");
        this.text_top.setText(2131427372);
    }
}

```

- Ta thấy được trong hàm buttonClick gọi đến hàm getFlag trong FlagstaffHill. Phân tích hàm ta được
- Hàm getFlag kiểm tra chuỗi đầu vào so với một chuỗi được lấy từ tài nguyên của ứng dụng (có ID là 2131427375). Tài nguyên này được lưu trữ tại Resources/res/values/strings.xml.



```

Fernflower Decompiler
package com.hellocmu.picoctf;

import android.content.Context;

public class FlagstaffHill {
    public static native String fenugreek(String var0);

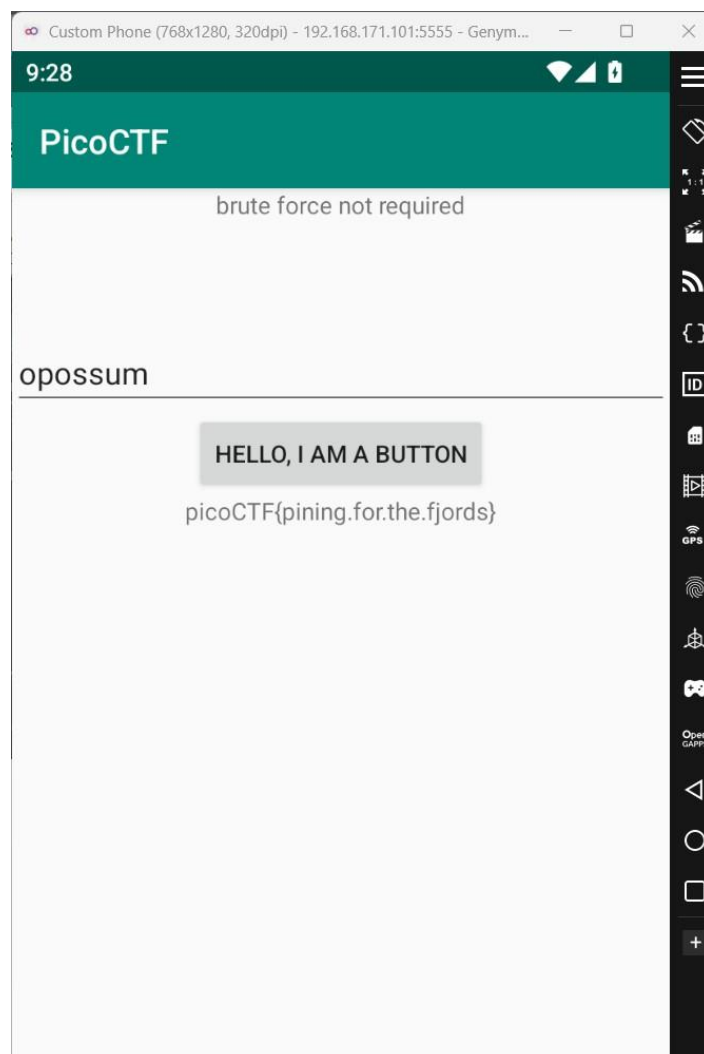
    public static String getFlag(String var0, Context var1) {
        return var0.equals(var1.getString(2131427375)) ? fenugreek(var0) : "NOPE";
    }
}

```

- Kiểm tra file strings.xml

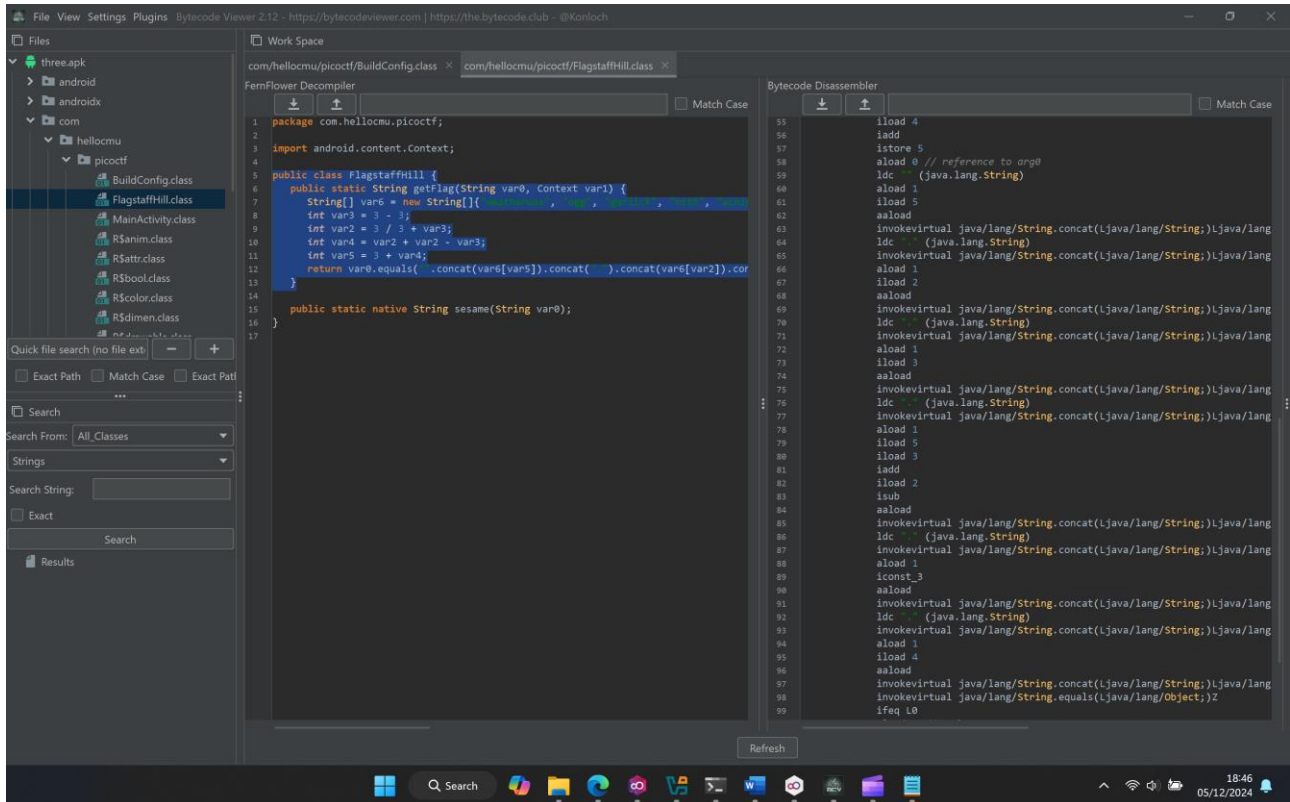
```
Workspace
com.hellocom.picoctf.MainActivity.class  com.hellocom.picoctf.FlagstaffHill.class  Decoded Resources/res/values/strings.xml
34  <string name="abc_searchview_description_clear">Clear query</string>
35  <string name="abc_searchview_description_query">Search query</string>
36  <string name="abc_searchview_description_search">Search</string>
37  <string name="abc_searchview_description_submit">Submit query</string>
38  <string name="abc_searchview_description_voice">Voice search</string>
39  <string name="abc_shareactionprovider_share_with">Share with</string>
40  <string name="abc_shareactionprovider_share_with_application">Share with %s</string>
41  <string name="abc_toolbar_collapse_description">Collapse</string>
42  <string name="app_name">PicoCTF</string>
43  <string name="bat">mink</string>
44  <string name="bear">margay</string>
45  <string name="cottontail">shrew</string>
46  <string name="gopher">armadillo</string>
47  <string name="hint">brute force not required</string>
48  <string name="manatee">caribou</string>
49  <string name="myotis">jackrabbit</string>
50  <string name="password">opossum</string>
51  <string name="porcupine">blackbuck</string>
52  <string name="porpoise">mouflon</string>
53  <string name="search_menu_title">Search</string>
54  <string name="skunk">elk</string>
55  <string name="status_bar_notification_info_overflow">999+</string>
56  <string name="vole">beaver</string>
57  </resources>
```

- Nhập thử opossum và kiểm tra:



⇒ Flag: picoCTF{pining.for.the.fjords}

Level 3:

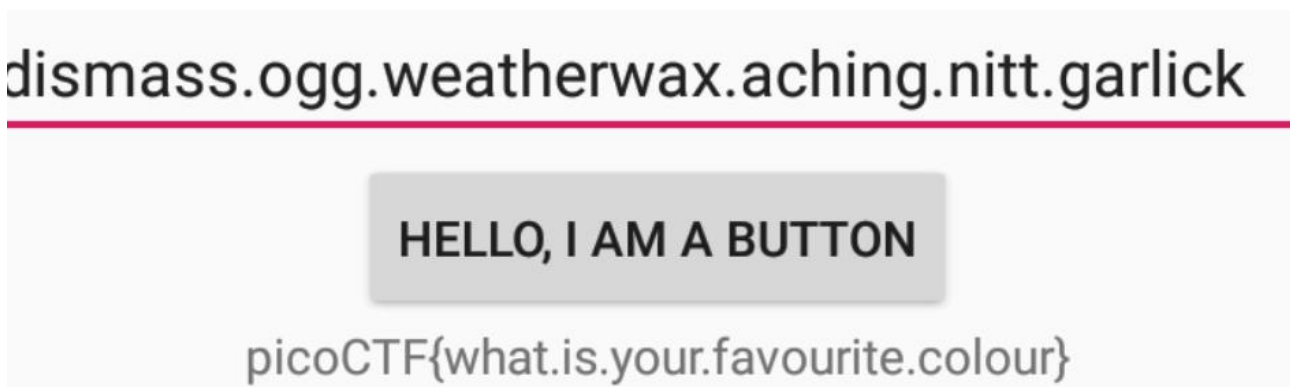


- Sử dụng ByteCode Viewer để phân tích three.apk. Ta thấy hàm buttonClick gọi đến hàm getFlag trong FlagstaffHill. Phân tích hàm getFlag ta được

```
public static String getFlag(String var0, Context var1) {
    String[] var6 = new String[]{"weatherwax", "ogg", "garlick", "nitt", "aching", "dismiss"};
    int var3 = 3 - 3; => var3 = 0
    int var2 = 3 / 3 + var3; => var2 = 1
    int var4 = var2 + var2 - var3; => var4 = 2
    int var5 = 3 + var4; => var5 = 5
    return
    var0.equals("".concat(var6[var5]).concat(".").concat(var6[var2]).concat(".").concat(var6[var3]).concat(".").concat(var6[var5 +
    var3 - var2]).concat(".").concat(var6[3]).concat(".").concat(var6[var4])) ? sesame(var0) : "NOPE";
}

dismiss.ogg.weatherwax.aching.nitt.garlick
flag: picoCTF{what.is.your.favourite.colour}
```

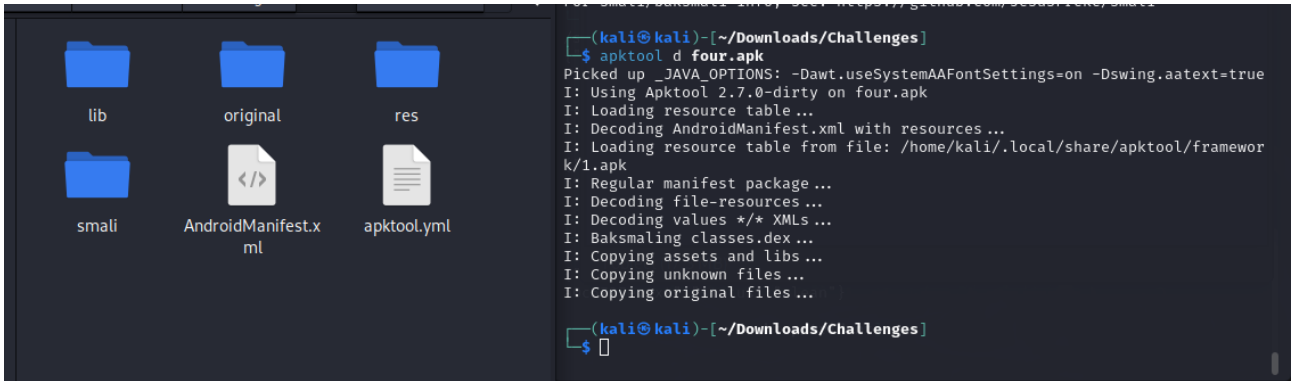
- Vậy chuỗi cần nhập là: dismiss.ogg.weatherwax.aching.nitt.garlick. Nhập chuỗi và kiểm tra



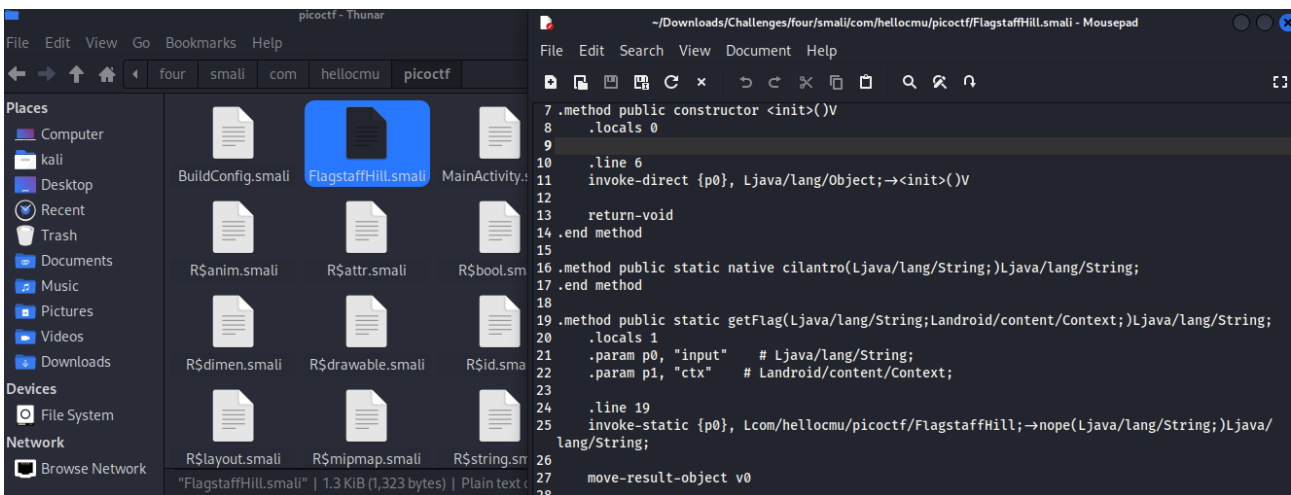
- Flag là: picoCTF{what.is.your.favourite.colour}

Level 4:

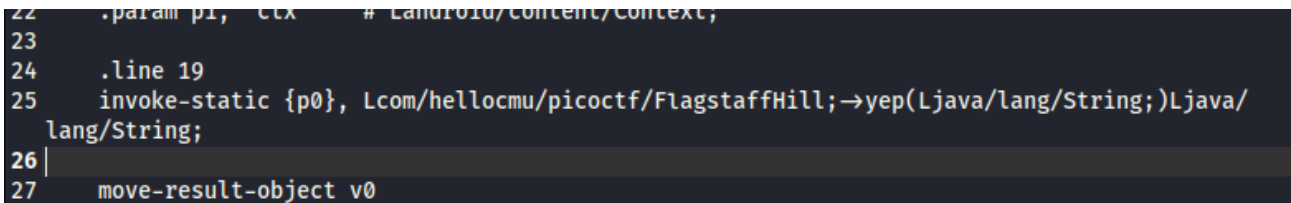
Dùng apktool để decompile



Truy cập vào file four/smali/com/hellocmu/picoctf/FlagstaffHill.smali



Chuyển hàm node thành yep:



Biên dịch lại thành apk

```

(kali@kali)-[~/Downloads/Challenges] apktool /usr/local/bin/
$ apktool b four -o fourv2.apk
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
I: Using Apktool 2.8.1
I: Checking whether sources has changed...
I: Smaling smali folder into classes.dex...
I: Checking whether resources has changed...
I: Building resources...
I: Copying libs... (/lib)
I: Building apk file...
I: Copying unknown files/dir...
I: Built apk into: fourv2.apk
(kali@kali)-[~/Downloads/Challenges]
$

```

Kí vào ứng dụng

```

File Actions Edit View Help
(kali@kali)-[~/Desktop]
$ wget https://raw.githubusercontent.com/1BotPeaches/apktool/master/scripts/linux/apktool
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
Enter keystore password:
Re-enter new password:
Enter the distinguished name. Provide a single dot (.) to leave a sub-component empty
or press ENTER to use the default value in braces.
What is your first and last name?
[Unknown]: tan pham
What is the name of your organizational unit?
[Unknown]: uit
What is the name of your organization?
[Unknown]: mmt
What is the name of your City or Locality?
[Unknown]: hcm
What is the name of your State or Province?
[Unknown]: td
What is the two-letter country code for this unit?
[Unknown]: 43000
Is CN=tan pham, OU=uit, O=mmt, L=hcm, ST=td, C=43000 correct?
[no]: y
Generating 2,048 bit RSA key pair and self-signed certificate (SHA384withRSA) with a v
alidity of 10,000 days
for: CN=tan pham, OU=uit, O=mmt, L=hcm, ST=td, C=43000
[Storing fourv2.keystore]

```

```

(kali@kali)-[~/Downloads/Challenges]
$ apksigner sign --ks fourv2.keystore fourv2.apk
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
Keystore password for signer #1:

```

Xóa file apk đã cài

```
Suggestion [3,General]: The command adb was not found, but does exist in the current location. Windows PowerShell does not load commands from the current location by default. If you trust this command, instead type: ".\adb". See "get-help about_Command_Precedence" for more details.
PS C:\Users\tanph\Downloads\platform-tools> .\adb -s 192.168.57.103:5555 shell pm list packages
package:com.genymotion.settings
package:com.android.cts.priv.ctsshim
package:com.android.internal.display.cutout.emulation.corner
package:com.example.android.livecubes
package:com.android.internal.display.cutout.emulation.double
package:com.android.providers.telephony
package:com.android.dynsystem
package:com.android.providers.calendar
package:com.android.providers.media
package:com.android.internal.systemui.navbar.gestural_wide_back
package:com.android.wallpapercropper
package:com.android.theme.color.cinnamon
package:com.android.theme.icon_pack.rounded.systemui
package:com.android.documentsui
package:com.android.externalstorage
package:com.android.htmlviewer
package:com.android.companiondevicemanager
```

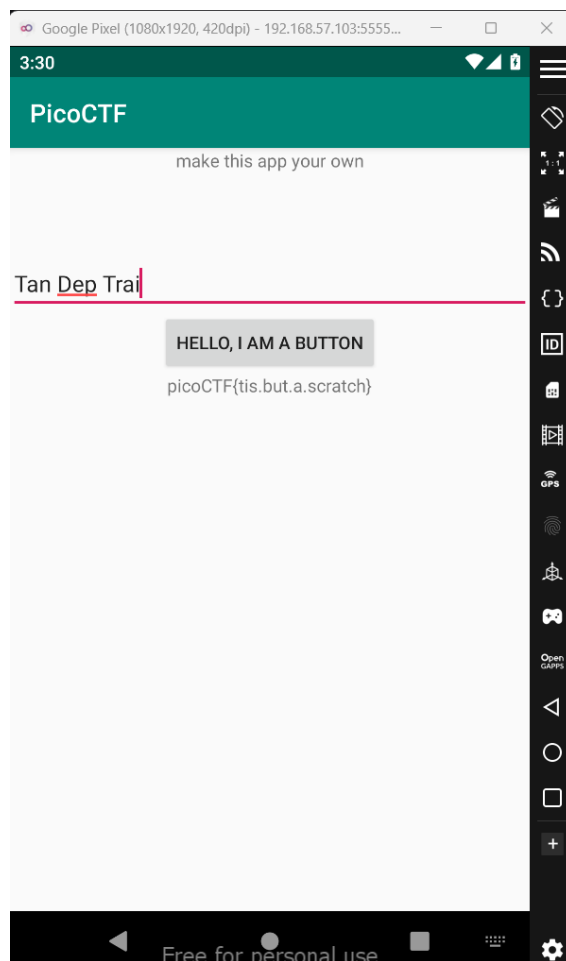
```
PS C:\Users\tanph\Downloads\platform-tools> .\adb -s 192.168.57.103:5555 shell am force-stop com.helloctu.picoctf
PS C:\Users\tanph\Downloads\platform-tools> .\adb -s 192.168.57.103:5555 uninstall com.helloctu.picoctf
Success
```

Xóa thành công

Cài đặt file apk mới

```
PS C:\Users\tanph\Downloads\platform-tools> .\adb -s 192.168.57.103:5555 install "C:\Users\tanph\Downloads\fourv2.apk"
Performing Streamed Install
Success
```

Sau khi cài ra thì nhấn cái gì cũng ra flag



Flag: picoCTF{tis.but.a.scratch}

Level 5:

- Ta decompile chương trình và xem thông tin trong FlagstaffHill:

```

1 package com.hellocmu.picocftf;
2
3 import android.content.Context;
4
5 /* loaded from: classes.dex */
6 public class FlagstaffHill {
7     public static native String cardamom(String str);
8
9     public static String getFlag(String input, Context ctx) {
10         StringBuilder ace = new StringBuilder("aaa");
11         StringBuilder jack = new StringBuilder("aaa");
12         StringBuilder queen = new StringBuilder("aaa");
13         StringBuilder king = new StringBuilder("aaa");
14         ace.setCharAt(0, (char) (ace.charAt(0) + 4));
15         ace.setCharAt(1, (char) (ace.charAt(1) + 19));
16         ace.setCharAt(2, (char) (ace.charAt(2) + 18));
17         jack.setCharAt(0, (char) (jack.charAt(0) + 7));
18         jack.setCharAt(1, (char) (jack.charAt(1) + 0));
19         jack.setCharAt(2, (char) (jack.charAt(2) + 1));
20         queen.setCharAt(0, (char) (queen.charAt(0) + 0));
21         queen.setCharAt(1, (char) (queen.charAt(1) + 11));
22         queen.setCharAt(2, (char) (queen.charAt(2) + 15));
23         king.setCharAt(0, (char) (king.charAt(0) + 14));
24         king.setCharAt(1, (char) (king.charAt(1) + 20));
25         king.setCharAt(2, (char) (king.charAt(2) + 15));
26         String password = "".concat(queen.toString()).concat(jack.toString()).concat(ace.toString()).concat(king.toString());
27         return input.equals(password) ? "call it" : "NOPE";
28     }
29 }

```

- Ở đây ta thấy thông tin chính là cũng kiểm tra password, dựa vào thông tin từ file java, thì code một file python để trả về password:

```

6 ace[0] = chr(ord(ace[0]) + 4)
7 ace[1] = chr(ord(ace[1]) + 19)
8 ace[2] = chr(ord(ace[2]) + 18)
9
10 jack[0] = chr(ord(jack[0]) + 7)
11 jack[1] = chr(ord(jack[1]) + 0)
12 jack[2] = chr(ord(jack[2]) + 1)
13
14 queen[0] = chr(ord(queen[0]) + 0)
15 queen[1] = chr(ord(queen[1]) + 11)
16 queen[2] = chr(ord(queen[2]) + 15)
17
18 king[0] = chr(ord(king[0]) + 14)
19 king[1] = chr(ord(king[1]) + 20)
20 king[2] = chr(ord(king[2]) + 15)
21
22 result = ''.join(queen) + ''.join(jack) + ''.join(ace) + ''.join(king)
23
24 print(result)

```

- Tuy nhiên ta thấy rằng kết quả trả về của getFlag lại là 1 chuỗi (“call it”), không phải flag ta mong muốn. Vì vậy ta cần điều hướng kết quả trả về là 1 hàm, cụ thể là hàm cardamon được khởi tạo ở trên.

- Ta sẽ invoke hàm cardamon, sau đó gán kết quả vào v0 và trả về v0:

```

SmallInject$2.smali      FlagstaffHill.smali
Tệp  Chỉnh sửa  Dạng xem
invoke-virtual {v4, v5}, Ljava/lang/String; -> concat(Ljava/lang/String;)Ljava/lang/String;
move-result-object v4
invoke-virtual {v1}, Ljava/lang/StringBuilder; -> toString()Ljava/lang/String;
move-result-object v5
invoke-virtual {v4, v5}, Ljava/lang/String; -> concat(Ljava/lang/String;)Ljava/lang/String;
move-result-object v4
.line 36
.local v4, "password":Ljava/lang/String;
invoke-virtual {p0, v4}, Ljava/lang/String; -> equals(Ljava/lang/Object;)Z
move-result v5
if-eqz v5, :cond_0
const-string v5, "call it"
return-object v5
.line 37
:cond_0
const-string v5, "NOPE"
return-object v5
end method

```

- Sửa thành:

```

SmallInject$2.smali      FlagstaffHill.smali
Tệp  Chỉnh sửa  Dạng xem
move-result-object v4
invoke-virtual {v1}, Ljava/lang/StringBuilder; -> toString()Ljava/lang/String;
move-result-object v5
invoke-virtual {v4, v5}, Ljava/lang/String; -> concat(Ljava/lang/String;)Ljava/lang/String;
move-result-object v4
.line 36
.local v4, "password":Ljava/lang/String;
invoke-virtual {p0, v4}, Ljava/lang/String; -> equals(Ljava/lang/Object;)Z
move-result v5
invoke-static {p0, Lcom/helloctf/picoctf/FlagstaffHill; -> cardamom(Ljava/lang/String;)Ljava/lang/String;
move-result-object v0
return-object v0
.line 37
:cond_0
const-string v5, "NOPE"

```

- Dùng lại key đã tạo ở bài EVASB 9, ta build lại file đã sửa thành pico.apk, ký file pico.apk, gỡ bản cũ rồi install lại:

```

Command Prompt
Microsoft Windows [Version 10.0.22631.4468]
(c) Microsoft Corporation. All rights reserved.

D:\HKS\NT213 - Bao mat web va ung dung\Lab\Lab4\Challenges>apktool d five.apk
I: Using Apktool 2.10.0 on five.apk with 8 thread(s).
I: Baksmaling classes.dex...
I: Loading resource table...
I: Decoding file-resources...
I: Loading resource table from file: C:\Users\Admin\AppData\Local\apktool\framework\1.apk
I: Decoding values */* XMLs...
I: Decoding AndroidManifest.xml with resources...
I: Regular manifest package...
I: Copying assets and libs...
I: Copying unknown files...
I: Copying original files...

D:\HKS\NT213 - Bao mat web va ung dung\Lab\Lab4\Challenges>apktool b five -o pico.apk
I: Using Apktool 2.10.0 with 8 thread(s).
I: Checking whether sources has changed...
I: Smaling small folder into classes.dex...
I: Checking whether resources has changed...
I: Building resources...
I: Copying libs... (/lib)
I: Building apk file...
I: Copying unknown files/dir...
I: Built apk into: pico.apk

D:\HKS\NT213 - Bao mat web va ung dung\Lab\Lab4\Challenges>jarsigner -keystore "D:\HKS\NT213 - Bao mat web va ung dung\Lab\Lab4\key.keystore" -storepass 123456 pico.apk PICO
jarsigner: Certificate chain not found for: PICO. PICO must reference a valid KeyStore key entry containing a private key and corresponding public key certificate chain.

D:\HKS\NT213 - Bao mat web va ung dung\Lab\Lab4\Challenges>jarsigner -keystore "D:\HKS\NT213 - Bao mat web va ung dung\Lab\Lab4\key.keystore" -storepass 123456 pico.apk CTF9
jar signed.

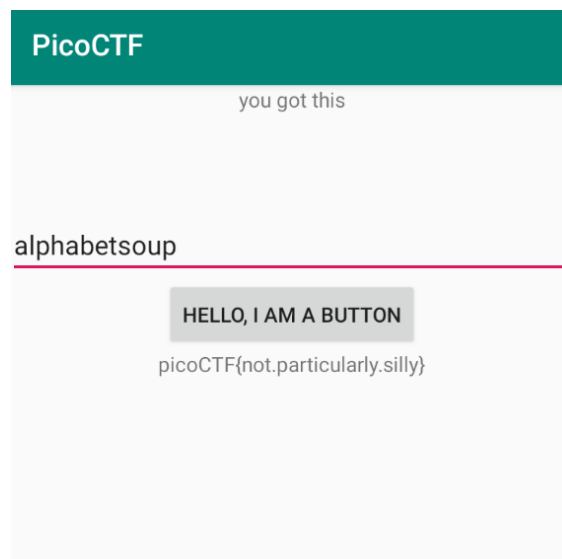
Warning:
The signer's certificate is self-signed.

D:\HKS\NT213 - Bao mat web va ung dung\Lab\Lab4\Challenges>adb i
ninstall pico.apk
Performing Streamed Install
adb: failed to install pico.apk: Failure [INSTALL_FAILED_UPDATE_INCOMPATIBLE: Package com.hellocmu.picoctf signatures do not match the previously installed version; ignoring!]

D:\HKS\NT213 - Bao mat web va ung dung\Lab\Lab4\Challenges>adb uninstall com.hellocmu.picoctf
Success

D:\HKS\NT213 - Bao mat web va ung dung\Lab\Lab4\Challenges>adb install pico.apk
Performing Streamed Install
Success
    
```

- Nhập pass và capture the flag. Flag là: picoCTF{not.particularly.silly}



----- HẾT -----